

CHAPITRE

21

Cybersécurité et environnement numérique sécurisé

ANSSI | cybermalveillance.gouv.fr | CERT Santé | Mots de passe | Authentification

DANS CE VOLUME

- ✓ Exercices progressifs
- ✓ Schémas à légender
- ✓ Mises en situation
- ✓ Corrigés détaillés

Sommaire

Cahier d'exercices – Chapitre 21 4
Mode d'emploi du cahier 4
Partie 1 – Enjeux, acteurs et objectifs de sécurité 6
Exercice 21.1 – Les acteurs de la cybersécurité en santé (10 points) 7
Exercice 21.2 – Disponibilité, intégrité, confidentialité (12 points) 9
Exercice 21.3 – Les mots de la sécurité (12 points) 11
Exercice 21.4 – Pourquoi la santé est-elle visée ? (14 points) 13
Exercice 21.5 – Deux jours sans logiciel de restauration (14 points) 15
Exercice 21.6 – Les textes et les référentiels (16 points) 17
Corrigés de la partie 1 19
Partie 2 – Un environnement de travail sécurisé 21
Exercice 21.7 – Les gestes d'hygiène informatique (12 points) 22
Exercice 21.8 – La règle 3-2-1 (12 points) 24
Exercice 21.9 – Combien de bilans perdus ? (14 points) 26
Exercice 21.10 – Le parc informatique d'une cuisine centrale (14 points) 28
Exercice 21.11 – Qui a besoin de quoi ? (14 points) 30
Exercice 21.12 – Où ranger les dossiers ? (16 points) 32
Corrigés de la partie 2 34
Partie 3 – Mots de passe et authentification 36
Exercice 21.13 – Un accès bien protégé (10 points) 37
Exercice 21.14 – Le temps de recherche d'un mot de passe (14 points) 39
Exercice 21.15 – La double authentification (12 points) 41
Exercice 21.16 – Le gestionnaire de mots de passe (14 points) 42
Exercice 21.17 – Le compte « cuisine » (14 points) 43
Exercice 21.18 – « Votre mot de passe a été divulgué » (16 points) 44
Corrigés de la partie 3 46
Partie 4 – Les actions malveillantes 48
Exercice 21.19 – Reconnaître l'attaque (12 points) 49
Exercice 21.20 – Le bon de livraison piégé (14 points) 51
Exercice 21.21 – Un appel trop curieux (14 points) 53
Exercice 21.22 – Le faux directeur (14 points) 54
Exercice 21.23 – Chronologie d'un rançongiciel (16 points) 55
Exercice 21.24 – Les arnaques qui visent les patients (16 points) 57
Corrigés de la partie 4 59
Partie 5 – Réagir à un incident et assurer la continuité 61
Exercice 21.25 – Les étapes de la réaction (10 points) 62
Exercice 21.26 – Le délai de 72 heures (12 points) 64
Exercice 21.27 – La fiche réflexe de la cuisine (14 points) 65
Exercice 21.28 – Le mode dégradé des repas (14 points) 66
Exercice 21.29 – Combien coûte une journée en mode dégradé ? (14 points) 68
Exercice 21.30 – Le retour d'expérience (16 points) 70
Corrigés de la partie 5 72
Partie 6 – Sensibiliser l'équipe et mesurer les progrès 75
Exercice 21.31 – Construire une sensibilisation (12 points) 76
Exercice 21.32 – Résultats d'un hameçonnage simulé (14 points) 78
Exercice 21.33 – Le progrès est-il réel ? (14 points) 79
Exercice 21.34 – Le questionnaire avant et après (14 points) 80
Exercice 21.35 – Le quart d'heure sécurité en cuisine (16 points) 81

Exercice 21.36 – Le tableau de bord de l'année (16 points) 82
Corrigés de la partie 6 84
Partie 7 – Hors les murs, objets connectés, petites structures et analyse de risque 87
Exercice 21.37 – Travailler hors de la structure (12 points) 88
Exercice 21.38 – La balance connectée (14 points) 90
Exercice 21.39 – Coter les risques (16 points) 91
Exercice 21.40 – La sécurité d'une diététicienne libérale (14 points) 93
Exercice 21.41 – Le Wi-Fi de la salle d'attente (14 points) 94
Exercice 21.42 – Les vieux ordinateurs (14 points) 95
Corrigés de la partie 7 96
Partie 8 – Synthèse et cas complet 99
Exercice 21.43 – La check-list cybersécurité d'un projet (12 points) 100
Exercice 21.44 – Relire la charte informatique (14 points) 101
Exercice 21.45 – Les questions du jury (12 points) 103
Exercice 21.46 – La note à la direction (14 points) 105
Exercice 21.47 – Choisir avec 2 500 € (16 points) 106
Exercice 21.48 – Cas complet : « Cure connectée » (40 points) 108
Corrigés de la partie 8 112
Bilan : grille d'auto-évaluation 116

Cahier d'exercices – Chapitre 21

Objectifs du chapitre (référentiel) – Objectifs du chapitre (référentiel)

- S'entraîner au niveau de l'épreuve E5 sur toutes les notions du chapitre 21 : les acteurs et les référentiels de la cybersécurité en santé ; les objectifs de sécurité ; l'environnement numérique de travail sécurisé (hygiène informatique, sauvegardes, droits d'accès, mots de passe et authentification) ; les actions malveillantes ; la réaction à un incident et la continuité de l'activité ; la sensibilisation des équipes ; le travail hors de la structure, les objets connectés et les petites structures (référentiel du 27 novembre 2024, compétences C3.1 à C3.6 ; guide d'accompagnement du 29 avril 2025).
- Légender des schémas : les acteurs, les objectifs de sécurité, les gestes d'hygiène informatique, la règle 3-2-1, un accès bien protégé, les actions malveillantes, les signes d'un message piégé, la réaction à un incident, la continuité de l'activité, la construction d'une action de sensibilisation, le travail hors de la structure.
- Calculer et interpréter : répartitions d'incidents, données perdues et temps de ressaisie, nombre de combinaisons et temps de recherche d'un mot de passe, délais de déclaration, coûts d'une panne et d'un plan de sécurité, taux de clic et de signalement, intervalles de confiance, scores de connaissances, cotation des risques.
- Concevoir, présenter et défendre le volet cybersécurité d'un projet d'intervention, comme au temps 1 de l'épreuve E5 et pendant l'entretien avec le jury.

Mode d'emploi du cahier

Ce cahier ne contient que des exercices construits comme les questions des épreuves : une mise en situation professionnelle, des documents (schémas, tableaux, messages, chronologies, résultats de campagnes), des questions notées en points et un corrigé détaillé. Les 48 exercices sont répartis en 8 parties de 6 exercices, de difficulté croissante. Après chaque exercice, un espace « Ma réponse » permet de rédiger directement dans le cahier. Les corrigés sont regroupés à la fin de chaque partie : ne les lisez qu'après avoir rédigé votre réponse.

Niveau	Ce qui est demandé	Repère de durée
★☆☆☆☆ Niveau 1	Restituer une définition, légender un schéma simple	Quelques minutes
★★☆☆☆ Niveau 2	Appliquer une notion en plusieurs étapes guidées	5 à 10 minutes
★★★☆☆ Niveau 3	Analyser des documents, choisir la méthode	10 à 20 minutes
★★★★☆ Niveau 4	Situation professionnelle courte	20 à 40 minutes
★★★★★ Niveau 5	Cas complet au format de l'épreuve	45 minutes à 2 heures

Les structures, personnes, messages, incidents, campagnes d'hameçonnage simulé, devis et budgets sont fictifs et construits pour l'entraînement : ils ne doivent pas être cités comme des données réelles. Les textes officiels et les repères présentés comme réels sont vérifiés en octobre 2026, et chaque référence est suivie de son année. Tous les calculs des corrigés ont été refaits et vérifiés ; les arrondis portent sur le résultat final. Les réponses proposées dans les corrigés sont des exemples : d'autres formulations sont acceptées si elles respectent la méthode et s'appuient sur les documents.

Méthode – Analyser la cybersécurité d'une situation

Pour chaque situation, posez cinq questions : **quelle information** est en jeu (et pour quelles personnes) ? **quel objectif** de sécurité est menacé (disponibilité, intégrité, confidentialité) ? **quelle faille** a été exploitée (un geste, un outil, une organisation) ? **que faire tout de suite** ? **quelle mesure durable** empêche que cela recommence ? Pensez toujours aux conséquences pour les personnes accompagnées : un repas non adapté ou une adresse volée sont des risques bien réels.

Partie 1 – Enjeux, acteurs et objectifs de sécurité

Objectifs – Objectifs de la partie

- Citer les acteurs de la cybersécurité en santé et leur rôle.
- Définir la disponibilité, l'intégrité et la confidentialité, et les reconnaître dans un incident.
- Distinguer menace, vulnérabilité, risque, incident et violation de données.
- Exploiter un tableau d'incidents pour expliquer pourquoi le secteur de la santé est exposé.
- Mesurer les conséquences d'une panne informatique pour les personnes accompagnées.
- Situer les principaux textes et référentiels.

À connaître par cœur pour le bts – À connaître par cœur

- La **cybersécurité** protège les informations et les outils numériques contre les pannes, les erreurs et les attaques.
- Trois objectifs principaux : **disponibilité** (l'information est accessible quand on en a besoin), **intégrité** (elle est exacte et complète), **confidentialité** (seules les personnes autorisées y accèdent). On y ajoute la **traçabilité** (savoir qui a fait quoi).
- **ANSSI** : autorité nationale de la sécurité des systèmes d'information (créée en 2009). **cybermalveillance.gouv.fr** : assistance aux victimes et prévention (depuis 2017). **CERT Santé** : appui de l'Agence du numérique en santé aux structures de santé. **CNIL** : reçoit les notifications de violations de données (72 heures). **17Cyber** : assistance et mise en relation avec un policier ou un gendarme (depuis le 17 décembre 2024).
- Le RGPD (2016, applicable depuis le 25 mai 2018), article 32, impose une **sécurité adaptée au risque**.
- En santé, une attaque informatique peut **retarder des soins ou des repas**, provoquer des **erreurs** (régime, texture, allergie) et **exposer des données de santé**.

Exercice 21.1 – Les acteurs de la cybersécurité en santé (10 points)

★☆☆☆☆ *Niveau 1 – restitution · durée conseillée : 10 min*

Mise en situation – Mise en situation

Vous effectuez votre stage dans un établissement d'hébergement pour personnes âgées dépendantes (EHPAD) de 90 lits (fictif). La directrice prépare une affiche « Qui appeler en cas de problème informatique ? » et vous demande de l'aider.

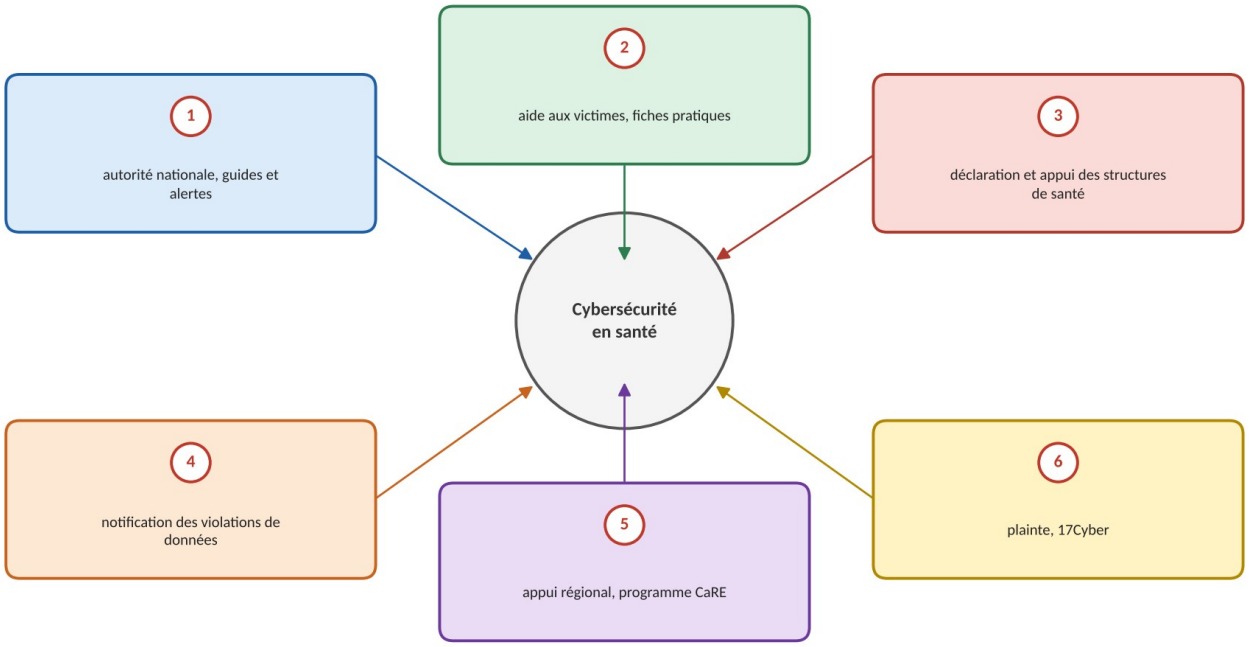


Figure 21.1 – Document 1 – Les acteurs de la cybersécurité en santé (schéma à légender)

À vous de jouer – Questions

1. Légendez les éléments numérotés 1 à 6 du document 1. (3 pts)
2. Pour chacune des situations suivantes, dites quel acteur la structure contacte : (a) un ordinateur portable contenant les plans de soins a été volé ; (b) la directrice veut un guide simple pour sécuriser les postes ; (c) un rançongiciel bloque le logiciel de soins ; (d) la structure veut porter plainte et être conseillée. (4 pts)
3. Expliquez en deux phrases la différence entre le rôle de la CNIL et celui de *cybermalveillance.gouv.fr*. (3 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.2 – Disponibilité, intégrité, confidentialité (12 points)

★☆☆☆☆ *Niveau 1 – restitution · durée conseillée : 10 min*

Mise en situation – Mise en situation

Le service diététique d'un centre de soins de suite et de réadaptation (fictif) a relevé six incidents en un an. Votre tutrice vous demande de les classer.

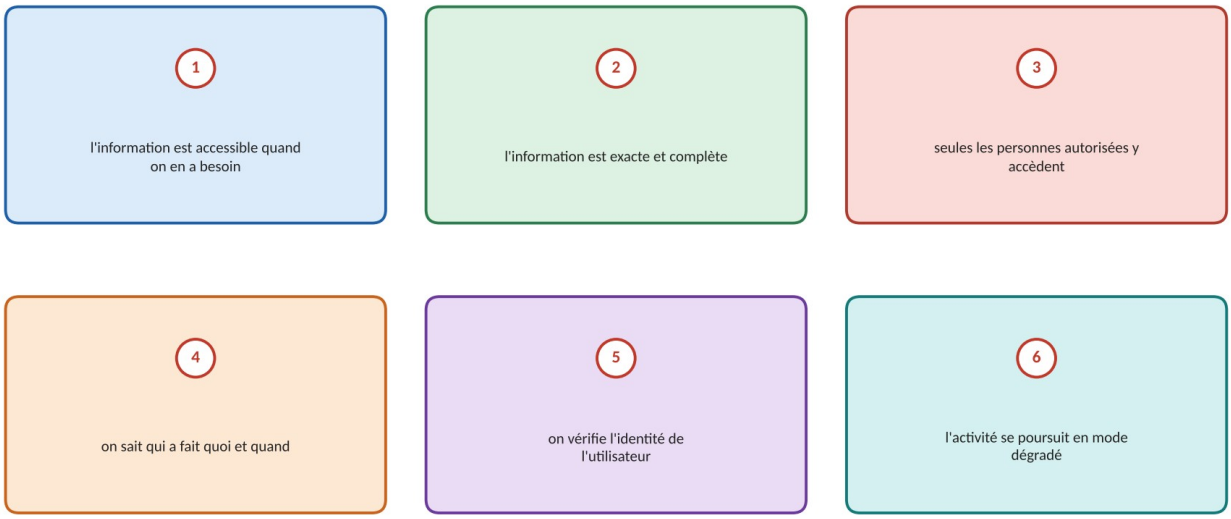


Figure 21.2 – Document 1 – Les objectifs de la sécurité de l'information (schéma à légender)

Document 2 – Six incidents

- **A.** Le logiciel de commande des repas est resté inaccessible un matin pendant 3 heures.
- **B.** Une texture « mixée » a été remplacée par « normale » dans le dossier d'un patient, sans que l'on sache qui l'a modifiée.
- **C.** Un listing des patients diabétiques a été envoyé par erreur à un fournisseur.
- **D.** Plusieurs agents utilisent le même identifiant pour se connecter au logiciel.
- **E.** Une clé USB contenant des bilans nutritionnels a été perdue dans le parking.
- **F.** Un fichier des menus de la semaine a été effacé et il n'existe aucune sauvegarde.

À vous de jouer – Questions

1. Légendez les éléments numérotés 1 à 6 du document 1. (3 pts)

2. Pour chaque incident du document 2, indiquez l'objectif de sécurité principalement atteint. (6 pts)

3. Expliquez, pour l'incident B, la conséquence possible pour le patient et pourquoi la traçabilité aurait aidé. (3 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.3 – Les mots de la sécurité (12 points)

★★☆☆☆ *Niveau 2 – application · durée conseillée : 10 min*

Mise en situation – Mise en situation

Avant une réunion avec le prestataire informatique, la diététicienne d'une cuisine centrale (fictive) veut être sûre d'employer les bons mots.

Document 1 – Les termes et les définitions (dans le désordre)

Terme	Définition
1. Menace	A. Faiblesse d'un outil ou d'une organisation qui peut être exploitée
2. Vulnérabilité	B. Événement qui a réellement porté atteinte à la sécurité
3. Risque	C. Ce qui peut porter atteinte à la sécurité (un attaquant, une panne, une erreur)
4. Incident	D. Incident qui touche des données personnelles : destruction, perte, modification, divulgation ou accès non autorisé
5. Violation de données	E. Combinaison de la vraisemblance d'un événement et de la gravité de ses conséquences

Document 2 – Une situation

Le poste de la cuisine fonctionne avec un système dont les mises à jour de sécurité ne sont plus fournies. Des groupes criminels diffusent des rançongiciels qui exploitent ce type de faille. Un vendredi, le poste est chiffré et les fiches des 46 résidents avec un régime ne sont plus lisibles.

À vous de jouer – Questions

1. Associez chaque terme à sa définition. (5 pts)

2. Dans le document 2, relevez la menace, la vulnérabilité et l'incident. (3 pts)

3. Cet incident est-il une violation de données au sens du RGPD ? Justifiez. (2 pts)

4. Proposez une mesure qui diminue la vraisemblance et une mesure qui diminue la gravité. (2 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.4 – Pourquoi la santé est-elle visée ? (14 points)

★★☆☆☆ *Niveau 2 – application · durée conseillée : 15 min*

Mise en situation – Mise en situation

Vous préparez une intervention de 15 minutes sur la cybersécurité pour une réunion des diététiciennes d'un territoire. Un groupement régional d'appui au développement de la e-santé (fictif) vous transmet le bilan des incidents qui lui ont été déclarés en 2027.

Document 1 – Incidents déclarés en 2027 par type (données fictives)

Type d'incident	Nombre
Hameçonnage (vol de mots de passe)	46
Rançongiciel	12
Fraude au virement	9
Perte ou vol de matériel	15
Erreur d'envoi (mauvais destinataire)	21
Panne chez un prestataire	17

Par type de structure : établissements de santé 58 ; établissements et services médico-sociaux 39 ; professionnels libéraux et centres de santé 23.

Document 2 – Un repère réel

En août 2022, le centre hospitalier Sud Francilien (Corbeil-Essonnes) a été touché par un rançongiciel : les logiciels ont été arrêtés, l'établissement a fonctionné en mode dégradé pendant plusieurs semaines et des données ont été publiées par les attaquants.

À vous de jouer – Questions

1. Calculez le nombre total d'incidents et la part de chaque type (en %, à 0,1 près). (4 pts)
2. Calculez la part des incidents dus à une action malveillante et la part des incidents non malveillants. Commentez. (3 pts)
3. Calculez la part de chaque type de structure. Pourquoi les petites structures déclarent-elles peut-être moins d'incidents qu'elles n'en subissent ? (3 pts)
4. Donnez trois raisons pour lesquelles les structures de santé intéressent les attaquants, en vous aidant du document 2. (4 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.5 – Deux jours sans logiciel de restauration (14 points)

★★★☆☆ *Niveau 3 – analyse · durée conseillée : 20 min*

Mise en situation – Mise en situation

La cuisine d'un centre hospitalier (fictif) produit **650 repas par jour** pour les patients ; **234** d'entre eux ont un régime ou une texture adaptée. Après une panne du serveur, le logiciel de commande des repas est resté inaccessible **deux jours**.

Document 1 – Le bilan des deux jours (données fictives)

- Les commandes ont été prises sur papier dans chaque service puis recopiées en cuisine.
- 2 diététiciennes ont travaillé chacune **4 heures de plus par jour** ; coût horaire chargé **30 €**.
- **5 erreurs** de régime ou de texture ont été relevées sur les deux jours ; taux habituel : **1,1 pour 1 000 repas**.
- La dernière liste papier des régimes datait de 3 semaines.

À vous de jouer – Questions

1. Calculez la part des repas adaptés. Que signifie ce chiffre pour l'organisation en mode dégradé ? (2 pts)

2. Calculez le nombre de repas des deux jours, le taux d'erreurs pour 1 000 repas et le nombre d'erreurs attendu au taux habituel. Comparez. (4 pts)

3. Calculez le coût des heures supplémentaires. Citez deux coûts qui ne sont pas comptés. (3 pts)

4. Quel objectif de sécurité a été atteint ? Proposez trois mesures pour la prochaine panne. (5 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.6 – Les textes et les référentiels (16 points)

★★★☆☆ *Niveau 3 – analyse · durée conseillée : 20 min*

Mise en situation – Mise en situation

Une association de diététiciennes libérales (fictive) prépare une fiche « Ce que dit la loi » pour ses adhérentes. On vous demande de vérifier les références.

Document 1 – Les textes et référentiels (données réelles)

N°	Texte ou référentiel
1	Règlement (UE) 2016/679 (RGPD), article 32
2	RGPD, articles 33 et 34
3	Code de la santé publique, article L1111-8
4	ANSSI, *Guide d'hygiène informatique* (2017)
5	Politique générale de sécurité des systèmes d'information de santé (PGSSI-S), Agence du numérique en santé (consultée en octobre 2026)
6	Directive (UE) 2022/2555 du 14 décembre 2022 (NIS 2)

Document 2 – Ce que l'on veut écrire sur la fiche

- **A.** « Toute violation de données doit être notifiée à la CNIL dans les 72 heures, même sans risque pour les personnes. »
- **B.** « Les données de santé de nos patients peuvent être stockées chez n'importe quel prestataire de stockage en ligne, s'il est en Europe. »
- **C.** « La sécurité doit être adaptée au risque : on ne protège pas une liste de recettes comme un dossier de patients. »
- **D.** « Le guide de l'ANSSI propose 42 mesures. »
- **E.** « La directive NIS 2 s'applique telle quelle à toutes les diététiciennes libérales depuis 2022. »
- **F.** « La PGSSI-S rassemble des référentiels et des guides de sécurité propres au secteur de la santé. »

À vous de jouer – Questions

1. Pour chaque phrase du document 2, dites si elle est exacte et associez-la au texte du document 1 qui la concerne. Corrigez les phrases inexactes. (9 pts)

2. Expliquez ce qu'est la double authentification et pourquoi les professionnels de santé utilisent la carte CPS ou l'e-CPS. (3 pts)

3. Rédigez trois lignes « Ce que je dois faire » pour une diététicienne libérale, à partir de ces textes. (4 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Corrigés de la partie 1

Corrigé – Exercice 21.1

1. Légendes : 1 ANSSI ; 2 *cybermalveillance.gouv.fr* ; 3 CERT Santé ; 4 CNIL ; 5 ARS et GRADeS ; 6 Police, gendarmerie.
2. (a) Vol d'un ordinateur avec des plans de soins : **CNIL** (violation de données de santé, notification dans les 72 heures si risque) et plainte (**gendarmerie ou police**). (b) Guide pour sécuriser les postes : **ANSSI** (guide d'hygiène informatique) ou fiches de *cybermalveillance.gouv.fr*. (c) Rançongiciel : **CERT Santé** (appui aux structures de santé), prestataire informatique, puis CNIL si des données sont touchées. (d) Plainte et conseils : **17Cyber** et le commissariat ou la brigade de gendarmerie.
3. La **CNIL** est l'autorité de contrôle de la protection des données : elle reçoit les notifications de violations, conseille et peut sanctionner. *cybermalveillance.gouv.fr* est un **dispositif d'assistance** : il aide les victimes à réagir, oriente vers des prestataires et publie des conseils ; il ne contrôle ni ne sanctionne.

Corrigé – Exercice 21.2

1. Légendes : 1 Disponibilité ; 2 Intégrité ; 3 Confidentialité ; 4 Traçabilité ; 5 Authentification ; 6 Continuité.
2. A : **disponibilité**. B : **intégrité** (donnée modifiée) et traçabilité (auteur inconnu). C : **confidentialité**. D : **traçabilité** et authentification (on ne sait pas qui agit). E : **confidentialité** (et disponibilité si c'était la seule copie). F : **disponibilité** (donnée perdue).
3. Le patient qui doit manger mixé peut recevoir des morceaux : risque de **fausse route**, d'étouffement ou de pneumopathie. Avec une traçabilité (comptes nominatifs, historique des modifications), on saurait **qui** a modifié la texture et **quand** : on pourrait comprendre l'erreur, la corriger vite et former la personne, sans accuser tout le service.

Corrigé – Exercice 21.3

1. 1-C ; 2-A ; 3-E ; 4-B ; 5-D.
2. **Menace** : les groupes criminels qui diffusent des rançongiciels. **Vulnérabilité** : le système qui ne reçoit plus de mises à jour de sécurité. **Incident** : le chiffrement du poste un vendredi.
3. Oui : les fiches de 46 résidents ne sont plus accessibles. La perte de disponibilité de données personnelles (ici des données de santé : régimes) est une **violation de données**, même si personne ne les a lues. Elle doit être inscrite au registre et notifiée à la CNIL si elle présente un risque.
4. **Vraisemblance** : remplacer le poste ou mettre à jour le système. **Gravité** : sauvegarde régulière avec une copie déconnectée, et liste papier des régimes à jour pour continuer à servir des repas sûrs.

Corrigé – Exercice 21.4

1. Total : 46 + 12 + 9 + 15 + 21 + 17 = **120 incidents**. Parts : hameçonnage 46 / 120 = **38,3 %** ; rançongiciel **10,0 %** ; fraude au virement **7,5 %** ; perte ou vol **12,5 %** ; erreur d'envoi **17,5 %** ; panne chez un prestataire **14,2 %**.
2. Actions malveillantes : 46 + 12 + 9 = 67, soit **55,8 %** ; incidents non malveillants : 53, soit **44,2 %**. Un peu plus de la moitié des incidents sont des attaques, mais près d'un incident sur deux vient d'une **erreur, d'un vol ou d'une panne** : la cybersécurité ne se limite pas aux pirates ; les gestes simples (vérifier le destinataire, chiffrer un portable) comptent autant.
3. Établissements de santé 58 / 120 = **48,3 %** ; médico-social **32,5 %** ; libéraux et centres de santé **19,2 %**. Les petites structures n'ont souvent ni service informatique ni référent : elles ne **repèrent** pas toujours les incidents, ne savent pas qu'elles peuvent les déclarer, ou les règlent seules. Le chiffre est donc probablement **sous-estimé**.
4. Les données de santé ont une **grande valeur** (revente, chantage) ; l'activité ne peut pas s'arrêter (les soins

et les repas sont vitaux), ce qui pousse à **payer** ou à céder vite ; les systèmes sont nombreux, anciens et reliés à beaucoup de partenaires ; les équipes sont pressées et peu formées. Le document 2 montre qu'un hôpital peut fonctionner des semaines en mode dégradé et voir ses données publiées.

Corrigé – Exercice 21.5

1. 234 / 650 × 100 = **36,0 %**, soit plus d'un repas sur trois. En mode dégradé, une liste papier fausse ou un oubli touche donc beaucoup de patients : il faut une liste **à jour** des régimes et un double contrôle.
2. Repas : 650 × 2 = **1 300**. Taux : 5 / 1 300 × 1 000 = **3,85 pour 1 000 repas**. Au taux habituel : 1,1 × 1 300 / 1 000 = 1,43, soit environ **1 à 2 erreurs**. Le taux est environ **3,5 fois** plus élevé (3,85 / 1,1), avec de petits nombres : l'écart est net mais imprécis.
3. 2 × 4 h × 2 jours = 16 h ; 16 × 30 € = **480 €**. Coûts non comptés : temps des soignants qui ont rempli les commandes papier, repas jetés ou refaits, temps du prestataire, conséquences pour les patients des erreurs, retard d'autres tâches des diététiciennes.
4. **Disponibilité** (et intégrité des informations utilisées, puisque la liste papier était ancienne). Mesures : imprimer chaque semaine la liste des régimes et textures (rangée sous clé) ; préparer des bons de commande papier et une **fiche réflexe** ; demander au prestataire un délai de rétablissement garanti et une sauvegarde testée ; faire un exercice de panne une fois par an.

Corrigé – Exercice 21.6

1.

Phrase	Exacte ?	Texte	Correction
A	Non	2	La notification à la CNIL dans les 72 heures est due **sauf si la violation n'est pas susceptible d'engendrer un risque** ; toute violation est en revanche inscrite au registre interne. Les personnes sont informées si le risque est élevé (article 34).
B	Non	3	Les données de santé confiées à un tiers doivent être hébergées chez un **hébergeur certifié HDS** ; être en Europe ne suffit pas.
C	Oui	1	Article 32 : mesures « appropriées » pour un niveau de sécurité adapté au risque.
D	Oui	4	Guide d'hygiène informatique de 2017 : 42 mesures.
E	Non	6	Une directive doit être **transposée** dans le droit national ; au 26 octobre 2026, la transposition en France n'était pas achevée, et elle vise surtout les entités d'une certaine taille ou importance.
F	Oui	5	La PGSSI-S est le corpus de sécurité propre à la santé (référentiels d'identification, d'authentification, guides).

2. La **double authentification** demande deux preuves de nature différente : ce que je **sais** (mot de passe, code), ce que je **possède** (carte, téléphone) ou ce que je **suis** (empreinte). Un mot de passe volé ne suffit plus pour entrer. La carte de professionnel de santé (CPS) ou sa version mobile, l'e-CPS, **prouvent l'identité du professionnel** pour accéder aux services de santé en ligne (par exemple via Pro Santé Connect).
3. Exemples : « Je range mes dossiers de patients uniquement dans un outil hébergé chez un hébergeur certifié HDS. » ; « J'active la double authentification et j'utilise un mot de passe différent pour chaque service. » ; « En cas de perte, de vol ou de piratage, je note les faits, je préviens la CNIL dans les 72 heures s'il y a un risque et je demande de l'aide à *cybermalveillance.gouv.fr*. »

Partie 2 – Un environnement de travail sécurisé

Objectifs – Objectifs de la partie

- Citer les gestes d'hygiène informatique et les repérer dans une situation de travail.
- Appliquer la règle 3-2-1 et juger une organisation des sauvegardes.
- Calculer les données perdues et le temps de ressaisie selon la fréquence des sauvegardes.
- Juger l'état d'un parc informatique et prioriser les mises à jour.
- Appliquer le principe du moindre privilège aux droits d'accès.
- Choisir un outil de stockage adapté à des données de santé.

À connaître par cœur pour le bts – À connaître par cœur

- Six gestes d'hygiène : **mots de passe** solides et uniques ; **mises à jour** appliquées ; **sauvegardes** régulières ; **comptes séparés** (pas de compte administrateur pour le travail quotidien) ; **verrouillage** de la session ; **vigilance** face aux messages, liens, pièces jointes et clés USB.
- Règle **3-2-1** : 3 exemplaires des données, sur 2 supports différents, dont 1 copie **hors ligne ou hors site**. Une sauvegarde qui n'a jamais été **restaurée** n'est pas une sauvegarde sûre.
- Une sauvegarde **branchée en permanence** est chiffrée en même temps que les données par un rançongiciel.
- **Moindre privilège** : chacun n'a accès qu'à ce dont il a besoin pour son travail ; les droits sont retirés au départ d'une personne.
- Les données de santé confiées à un prestataire sont hébergées chez un **hébergeur certifié HDS** (article L1111-8 du code de la santé publique).

Exercice 21.7 – Les gestes d'hygiène informatique (12 points)

★☆☆☆☆ *Niveau 1 – restitution · durée conseillée : 10 min*

Mise en situation – Mise en situation

Vous passez une matinée dans le bureau de la diététicienne d'un service de soins infirmiers à domicile (SSIAD, fictif). Vous notez ce que vous observez.

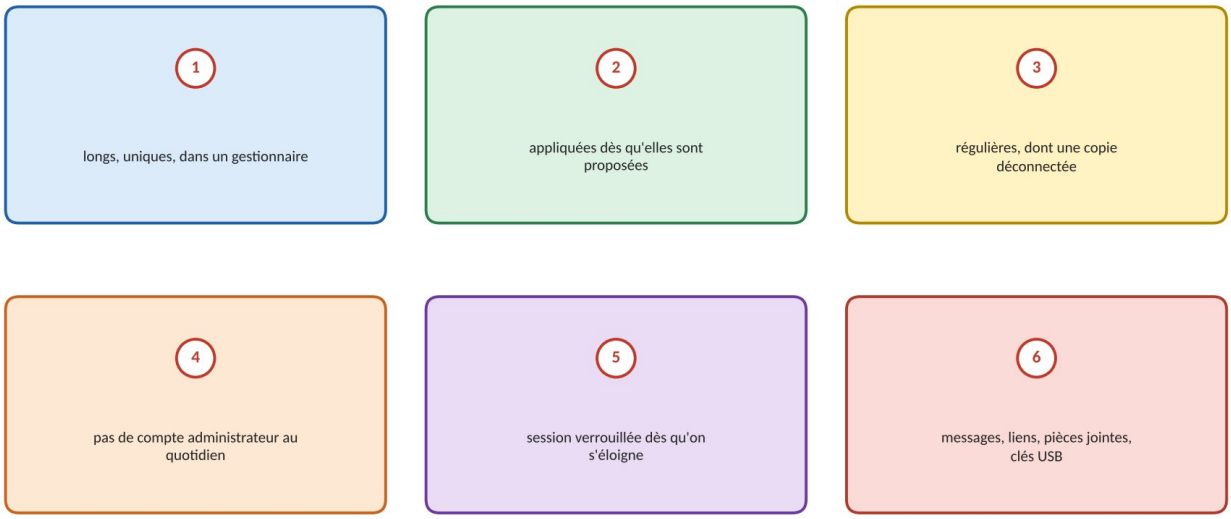


Figure 21.3 – Document 1 – Les gestes d'hygiène informatique (schéma à légender)

Document 2 – Vos observations

- **A.** L'ordinateur affiche depuis trois semaines « Des mises à jour sont prêtes, redémarrer plus tard ».
- **B.** La diététicienne quitte le bureau 20 minutes, la session reste ouverte sur un dossier.
- **C.** Le même mot de passe sert pour la messagerie, le logiciel de soins et un site de recettes.
- **D.** Une clé USB publicitaire reçue lors d'un salon est branchée « pour voir ce qu'elle contient ».
- **E.** La session de travail quotidienne a tous les droits d'administration de l'ordinateur.
- **F.** Les bilans nutritionnels ne sont copiés nulle part ailleurs que sur le disque de l'ordinateur.

À vous de jouer – Questions

1. Légendez les éléments numérotés 1 à 6 du document 1. (3 pts)

2. Associez chaque observation du document 2 au geste d'hygiène qui n'est pas respecté. (6 pts)

3. Choisissez les deux observations les plus urgentes à corriger et justifiez. (3 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.8 – La règle 3-2-1 (12 points)

★★☆☆☆ *Niveau 2 – application · durée conseillée : 15 min*

Mise en situation – Mise en situation

Trois diététiciennes libérales (fictives) vous décrivent leurs sauvegardes lors d'une réunion de leur association.

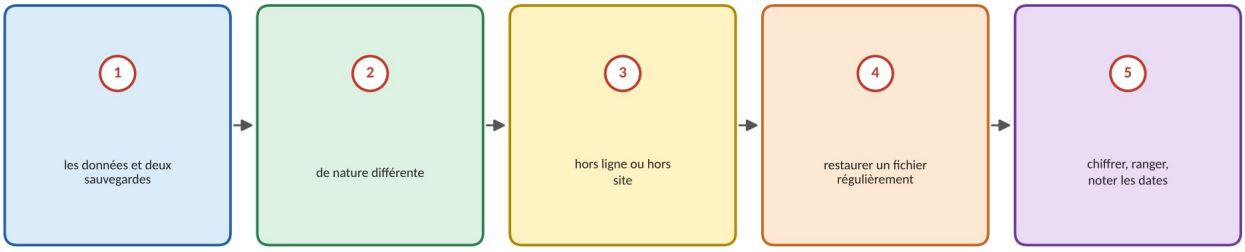


Figure 21.4 – Document 1 – La règle 3-2-1 et la restauration (schéma à légender)

Document 2 – Trois organisations

- **Mme Lenoir** : ses dossiers sont sur son ordinateur ; elle les copie chaque soir sur un disque externe qui reste branché.
- **M. Morel** : ses dossiers sont dans un logiciel en ligne hébergé chez un hébergeur certifié HDS, qui fait des sauvegardes chaque jour ; il exporte une fois par mois ses dossiers sur une clé USB chiffrée, rangée chez lui. Il n'a jamais essayé de restaurer un fichier.
- **Mme Garnier** : ses dossiers sont sur son ordinateur ; chaque vendredi, elle les copie sur un disque externe chiffré qu'elle débranche et range dans un tiroir fermé ; une seconde copie chiffrée part chaque nuit chez un hébergeur certifié HDS. Elle teste une restauration tous les trois mois.

À vous de jouer – Questions

1. Légendez les éléments numérotés 1 à 5 du document 1. (2,5 pts)

2. Pour chaque diététicienne, dites si la règle 3-2-1 est respectée et ce qui manque. (6 pts)

3. Expliquez pourquoi l'organisation de Mme Lenoir ne la protège pas d'un rançongiciel, et ce qu'elle peut changer sans dépenser plus de 100 €. (3,5 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.9 – Combien de bilans perdus ? (14 points)

★★☆☆☆ *Niveau 2 – application · durée conseillée : 15 min*

Mise en situation – Mise en situation

Le service diététique d'un centre de rééducation (fictif) saisit ses bilans nutritionnels sur un serveur interne. Il compare trois organisations de sauvegarde avant d'en choisir une.

Document 1 – Les données (fictives)

- Activité : **18 bilans** saisis par jour ouvré, du lundi au vendredi, répartis régulièrement de 8 h à 17 h ; un bilan demande **25 minutes** de saisie.
- Le serveur contient **4 200 bilans** (historique de trois ans).
- Hypothèse : un rançongiciel chiffre le serveur un **jeudi à 11 h**.
- **Organisation A** : sauvegarde chaque dimanche à 20 h sur un disque qui est ensuite débranché.
- **Organisation B** : sauvegarde chaque soir à 20 h vers un hébergeur, sur un espace non accessible depuis le réseau du centre.
- **Organisation C** : sauvegarde chaque soir à 20 h sur un disque réseau du centre, toujours connecté.

À vous de jouer – Questions

1. Calculez le nombre de bilans saisis le jeudi entre 8 h et 11 h. (2 pts)
2. Pour les organisations A et B, calculez le nombre de bilans perdus et le temps de ressaisie (en heures et minutes). (5 pts)
3. Que se passe-t-il avec l'organisation C ? Calculez le temps de ressaisie dans le pire des cas. (4 pts)
4. Quelle organisation recommandez-vous ? Quelle donnée manque-t-il pour décider (deux exemples) ? (3 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.10 – Le parc informatique d'une cuisine centrale (14 points)

★★★☆☆ *Niveau 3 – analyse · durée conseillée : 15 min*

Mise en situation – Mise en situation

La cuisine centrale d'une communauté de communes (fictive) prépare 2 100 repas par jour pour les écoles et le portage. La diététicienne fait l'inventaire des postes informatiques avec le prestataire.

Document 1 – L'inventaire (données fictives)

Situation des postes	Nombre	Exemples d'usage
À jour	9	Bureau, gestion des menus, comptabilité
Mises à jour en attente depuis plus de 30 jours	4	Poste de réception des marchandises, poste du chef
Système qui ne reçoit plus de mises à jour de sécurité	2	Poste relié à la sonde de température des chambres froides, ancien poste de la diététicienne

Devis : remplacement d'un poste, **690 €** (fictif). Budget informatique de l'année : **4 000 €**.

À vous de jouer – Questions

1. Calculez la part de chaque situation (en %, à 0,1 près). (3 pts)
2. Expliquez pourquoi un poste non mis à jour est une porte d'entrée pour les attaquants. (2 pts)
3. Le poste relié aux sondes de température ne peut pas être remplacé tout de suite (logiciel du fabricant). Proposez trois mesures de protection en attendant. (4 pts)
4. Calculez le coût du remplacement des deux postes obsolètes et sa part du budget. Proposez une règle simple pour que les mises à jour ne restent plus en attente. (5 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.11 – Qui a besoin de quoi ? (14 points)

★★★☆☆ *Niveau 3 – analyse · durée conseillée : 20 min*

Mise en situation – Mise en situation

Dans la cuisine d'un établissement de santé mentale (fictif), le logiciel de restauration a été installé avec un seul niveau de droits : tout le monde peut tout voir et tout modifier. La diététicienne vous demande de proposer une nouvelle organisation des droits.

Document 1 – Les droits actuels (O = accès ; données fictives)

Rôle	Dossiers nutritionnels	Liste des régimes et textures	Factures fournisseurs	Administration du logiciel
Diététiciennes	O	O	O	O
Cuisiniers	O	O	O	O
Secrétaire	O	O	O	O
Stagiaire de BTS	O	O	O	O
Prestataire informatique	O	O	O	O

Le stagiaire utilise le compte de la diététicienne ; un cuisinier parti il y a six mois a encore son compte actif.

À vous de jouer – Questions

1. Définissez le principe du moindre privilège. (2 pts)
2. Reproduisez le tableau en ne gardant que les accès nécessaires à chaque rôle. Justifiez deux choix. (5 pts)
3. Calculez le nombre d'accès actuels, le nombre d'accès nécessaires et la part d'accès en trop. (3 pts)
4. Que faut-il faire pour le stagiaire et pour le cuisinier parti ? Quel objectif de sécurité est concerné ? (4 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.12 – Où ranger les dossiers ? (16 points)

★★★☆☆ *Niveau 3 – analyse · durée conseillée : 20 min*

Mise en situation – Mise en situation

Un cabinet de quatre diététiciennes (fictif) réalise environ **1 800 consultations par an**. Il range aujourd'hui ses dossiers sur un service de stockage en ligne gratuit et grand public. Il compare trois solutions sur **3 ans**.

Document 1 – Les solutions (offres fictives, 2028)

Solution	Description	Coût
A	Garder le stockage en ligne gratuit grand public (serveurs hors Union européenne, pas de certification HDS)	0 €
B	Espace de stockage chez un hébergeur certifié HDS, double authentification	12 € par utilisatrice et par mois, plus 150 € de mise en service
C	Logiciel de suivi diététique hébergé chez un hébergeur certifié HDS (dossiers, agenda, courriers)	59 € par mois pour le cabinet

À vous de jouer – Questions

1. Expliquez pourquoi la solution A n'est pas acceptable pour des dossiers de patients. (3 pts)

2. Calculez le coût sur 3 ans des solutions B et C, puis le coût par consultation. (5 pts)

3. Citez quatre critères, autres que le prix, pour choisir entre B et C. (4 pts)

4. Rédigez trois questions à poser au fournisseur avant de signer. (4 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Corrigés de la partie 2

Corrigé – Exercice 21.7

1. Légendes : 1 Mots de passe ; 2 Mises à jour ; 3 Sauvegardes ; 4 Comptes séparés ; 5 Verrouillage ; 6 Vigilance.
2. A : **mises à jour**. B : **verrouillage**. C : **mots de passe** (un mot de passe unique par service). D : **vigilance** (support inconnu). E : **comptes séparés** (compte d'utilisateur sans droits d'administration). F : **sauvegardes**.
3. Exemples : **D**, car une clé inconnue peut installer un programme malveillant dès qu'elle est branchée : il faut prévenir le référent ou le prestataire tout de suite ; **F**, car une panne, un vol ou un rançongiciel ferait perdre tous les bilans, sans retour possible. On accepte aussi **C** (un seul vol de mot de passe ouvre tous les services) si la réponse est justifiée.

Corrigé – Exercice 21.8

1. Légendes : 1 3 copies ; 2 2 supports ; 3 1 copie à l'écart ; 4 Tester ; 5 Protéger.
2. **Mme Lenoir** : 2 copies seulement, et aucune n'est à l'écart (disque toujours branché) : **non respectée**. **M. Morel** : les données et les sauvegardes de l'hébergeur, plus la clé USB chiffrée hors du cabinet : 3 copies, 2 supports, 1 à l'écart : **respectée sur le papier**, mais l'export n'a lieu qu'**une fois par mois** (jusqu'à un mois de dossiers à retrouver si l'hébergeur fait défaut) et il n'a **jamais testé** la restauration. **Mme Garnier** : ordinateur, disque débranché, copie chez l'hébergeur : 3 copies, 2 supports, 2 copies à l'écart, chiffrement et tests : **respectée**.
3. Un rançongiciel chiffre tout ce qui est accessible depuis l'ordinateur, y compris un **disque branché** : la sauvegarde est perdue en même temps que les données. Sans dépense, ou presque : **débrancher** le disque après chaque copie ; acheter un **second disque** (moins de 100 €) et alterner les deux, l'un restant rangé hors du cabinet ; **chiffrer** les disques ; **tester** une restauration chaque mois.

Corrigé – Exercice 21.9

1. 18 bilans en 9 heures, soit 2 bilans par heure ; de 8 h à 11 h : 3 × 2 = **6 bilans**.
2. **A** : dernière sauvegarde le dimanche à 20 h. Perte : lundi, mardi, mercredi (3 × 18 = 54) + jeudi matin (6) = **60 bilans**, soit 60 × 25 = 1 500 minutes = **25 h** de ressaisie. **B** : dernière sauvegarde le mercredi à 20 h. Perte : **6 bilans**, soit 150 minutes = **2 h 30**.
3. Le disque réseau est **toujours connecté** : le rançongiciel peut le chiffrer aussi. Dans le pire des cas, les **4 200 bilans** sont perdus : 4 200 × 25 = 105 000 minutes = **1 750 heures**, soit plus d'une année de travail à temps plein ; en pratique, une grande partie ne pourrait jamais être retrouvée.
4. **B** : perte la plus faible et copie inaccessible au rançongiciel. Données manquantes : le **coût** de chaque solution ; le **délai de restauration** (combien d'heures pour tout récupérer) ; la certification HDS de l'hébergeur ; les tests de restauration prévus.

Corrigé – Exercice 21.10

1. Total : 15 postes. À jour : 9 / 15 = **60,0 %** ; mises à jour en attente : 4 / 15 = **26,7 %** ; système obsolète : 2 / 15 = **13,3 %**.
2. Les mises à jour corrigent des **failles connues**. Une fois la faille publiée, les attaquants l'exploitent automatiquement sur tous les postes qui ne sont pas corrigés : plus la mise à jour attend, plus le risque augmente. Un poste obsolète ne sera **jamais** corrigé.
3. **Isoler** le poste du reste du réseau et d'Internet (il ne communique qu'avec les sondes) ; ne l'utiliser **que** pour les températures (pas de messagerie, pas de navigation, pas de clé USB) ; **compte sans droits d'administration** et mot de passe solide ; relevé papier des températures en secours ; demander au

fabricant une date de mise à jour.

4. 2 × 690 = **1 380 €**, soit 1 380 / 4 000 = **34,5 %** du budget. Règle : « Les mises à jour sont installées **chaque mardi à 17 h** (redémarrage) ; le prestataire vérifie chaque mois la liste des postes en retard. » Le poste de la diététicienne, qui contient des données de santé, est remplacé en premier.

Corrigé – Exercice 21.11

1. **Moindre privilège** : chaque personne n'a accès qu'aux informations et aux fonctions dont elle a besoin pour son travail, et seulement le temps nécessaire.

2.

Rôle	Dossiers nutritionnels	Liste des régimes et textures	Factures fournisseurs	Administration du logiciel
Diététiciennes	O	O	–	–
Cuisiniers	–	O	–	–
Secrétaire	–	–	O	–
Stagiaire de BTS	O (sous la responsabilité de la tutrice)	O	–	–
Prestataire informatique	–	–	–	O

Exemples de justification : les cuisiniers ont besoin de savoir **quoi préparer** (régime, texture, allergie), pas du **dossier nutritionnel** (poids, diagnostic, histoire de vie) ; le prestataire administre le logiciel mais n'a pas à lire les dossiers (s'il intervient sur une base, c'est dans le cadre d'un contrat de sous-traitance).

3. Accès actuels : 5 × 4 = **20**. Accès nécessaires : 2 + 1 + 1 + 2 + 1 = **7**. Accès en trop : 13, soit 13 / 20 = **65 %**.

4. Le stagiaire reçoit **son propre compte**, avec des droits limités et une date de fin ; il ne doit jamais utiliser celui de la diététicienne. Le compte du cuisinier parti est **désactivé immédiatement** ; on prévoit une procédure de départ (liste des accès à retirer le dernier jour). Objectifs concernés : **confidentialité** (accès d'une personne qui n'a plus de raison d'accéder) et **traçabilité** (on ne sait pas qui, du stagiaire ou de la diététicienne, a fait une action).

Corrigé – Exercice 21.12

1. La solution A n'est pas certifiée **HDS** : or les données de santé conservées pour le compte du cabinet doivent être hébergées chez un hébergeur certifié (article L1111-8). Les serveurs hors Union européenne posent aussi la question des **transferts** de données (RGPD). Enfin, l'outil grand public n'offre pas toujours de double authentification ni de contrat précisant la sécurité, la réversibilité et le sort des données.

2. **B** : 12 × 4 × 36 = 1 728 € ; + 150 € = **1 878 €** sur 3 ans. **C** : 59 × 36 = **2 124 €**. Consultations sur 3 ans : 1 800 × 3 = 5 400. Coût par consultation : B : 1 878 / 5 400 = **0,35 €** ; C : 2 124 / 5 400 = **0,39 €**. L'écart (246 € sur 3 ans) est faible au regard du service rendu.

3. Exemples : double authentification et comptes nominatifs ; sauvegardes et délai de restauration garantis ; possibilité d'**exporter** toutes les données dans un format lisible (réversibilité) ; facilité d'usage et temps gagné (courriers, agenda) ; assistance en cas de problème ; journal des accès ; compatibilité avec la messagerie sécurisée de santé.

4. « Pouvez-vous me fournir votre **certificat HDS** et le périmètre qu'il couvre ? » ; « Où sont **hébergées** les données et qui y a accès chez vous ? » ; « Comment **récupérer** toutes mes données si je quitte votre service, et dans quel délai sont-elles supprimées ? » ; « Quel est le **délai** de rétablissement en cas de panne ou d'attaque, et comment serai-je informée d'un incident ? »

Partie 3 – Mots de passe et authentification

Objectifs – Objectifs de la partie

- Citer les règles d'un accès bien protégé.
- Juger la solidité d'un mot de passe et proposer une phrase de passe.
- Calculer un nombre de combinaisons et un temps de recherche.
- Expliquer la double authentification et reconnaître les facteurs utilisés.
- Justifier l'usage d'un gestionnaire de mots de passe et en chiffrer le coût.
- Réagir à la fuite d'un mot de passe et supprimer un compte partagé.

À connaître par cœur pour le bts – À connaître par cœur

- Un mot de passe est solide s'il est **long**, **imprévisible** et **unique** (un par service). La CNIL (recommandation de 2022) donne des exemples : 12 caractères mêlant majuscules, minuscules, chiffres et caractères spéciaux, ou une **phrase de passe** d'au moins 7 mots, quand le mot de passe est utilisé seul.
- Nombre de combinaisons = (nombre de caractères possibles) puissance (longueur). Chaque caractère en plus **multiplie** le nombre de combinaisons.
- Un mot de passe construit à partir d'un prénom, d'une date ou du nom de la structure est trouvé en quelques secondes avec des listes de mots.
- **Double authentification** : deux preuves de nature différente (ce que je sais, ce que je possède, ce que je suis).
- Un **gestionnaire de mots de passe** retient des mots de passe longs et différents ; on ne retient qu'un seul mot de passe maître, très solide.
- Un compte **partagé** empêche de savoir qui a fait quoi (traçabilité) et ne peut pas être retiré à une seule personne.

Exercice 21.13 – Un accès bien protégé (10 points)

★☆☆☆☆ *Niveau 1 – restitution · durée conseillée : 10 min*

Mise en situation – Mise en situation

Vous animez un « quart d'heure sécurité » dans un centre de santé (fictif). Vous projetez un schéma, puis vous demandez aux participants de juger six mots de passe.

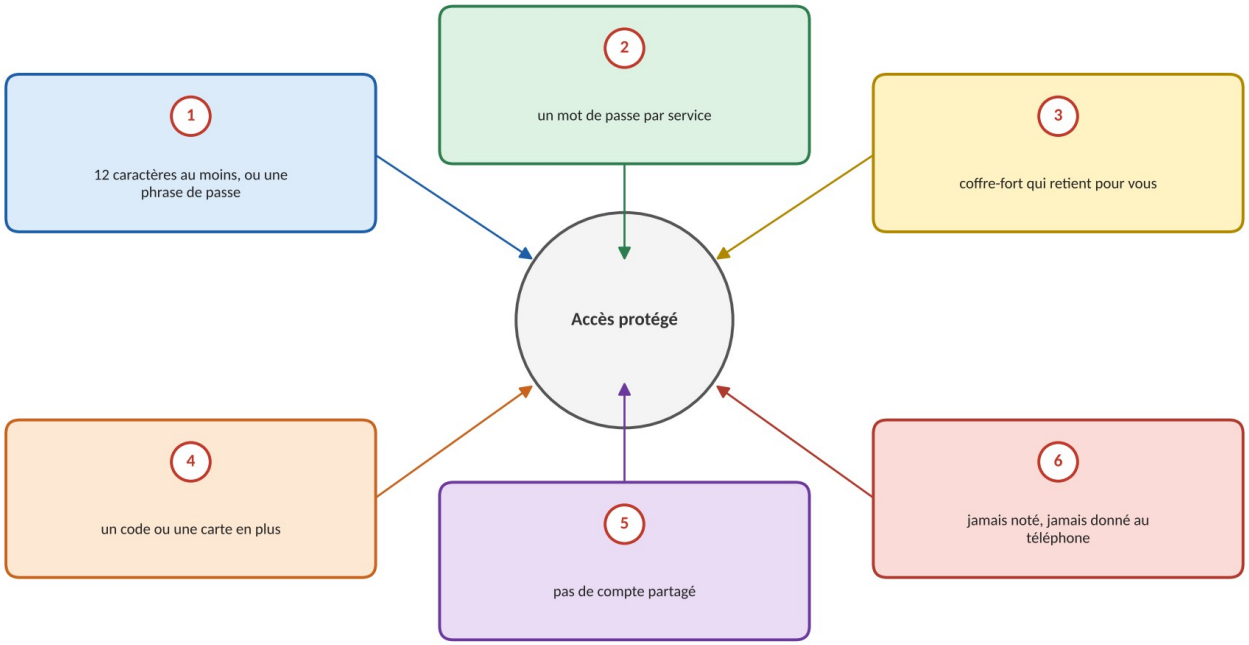


Figure 21.5 – Document 1 – Un accès bien protégé (schéma à légender)

Document 2 – Six mots de passe proposés par les participants

1. « Diet2028! »
2. « 123456 »
3. « Lucas14072015 » (prénom et date de naissance de son fils)
4. « CentreSante » (le nom de la structure)
5. « carotte-velo-nuage-piano-orage-tulipe-brique »
6. « k7#Vq!2pLz9&Wm »

À vous de jouer – Questions

1. Légendez les éléments numérotés 1 à 6 du document 1. (3 pts)
2. Classez les six mots de passe en « faibles » et « solides » et justifiez chaque choix en une ligne. (5 pts)
3. Entre les mots de passe 5 et 6, lequel conseillez-vous pour ouvrir un gestionnaire de mots de passe ? Pourquoi ? (2 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.14 – Le temps de recherche d'un mot de passe (14 points)

★★☆☆☆ *Niveau 2 – application · durée conseillée : 15 min*

Mise en situation – Mise en situation

Pour convaincre l'équipe d'un service de nutrition clinique (fictif) de changer ses habitudes, vous comparez le temps nécessaire pour tester **toutes** les combinaisons de plusieurs types de mots de passe.

Document 1 – Les hypothèses

- Un attaquant a volé une base de mots de passe protégés ; il peut tester **10 puissance 10** combinaisons par seconde (hypothèse).
- Type 1 : code de 6 chiffres. Type 2 : 8 caractères parmi 62 (minuscules, majuscules, chiffres). Type 3 : 10 caractères parmi 94 (tous les caractères du clavier). Type 4 : phrase de passe de 7 mots tirés au hasard dans une liste de 7 776 mots.
- Repère : une année compte environ 31,6 millions de secondes.

À vous de jouer – Questions

1. Calculez le nombre de combinaisons de chaque type (écrivez-le sous la forme « a × 10 puissance n »). (4 pts)
2. Calculez le temps de recherche de chaque type, dans l'unité la plus parlante. (5 pts)
3. Une carte bancaire n'a qu'un code de 4 chiffres. Pourquoi est-ce suffisant ? (2 pts)
4. Concluez par un conseil pour l'équipe. (3 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.15 – La double authentification (12 points)

★★☆☆☆ *Niveau 2 – application · durée conseillée : 10 min*

Mise en situation – Mise en situation

Le prestataire d'une maison de santé pluriprofessionnelle (fictive) propose d'activer la double authentification sur la messagerie et le logiciel partagé. Plusieurs professionnels s'inquiètent : « Ça va nous faire perdre du temps. »

Document 1 – Six moyens de se connecter

- **A.** Mot de passe seul.
- **B.** Mot de passe et code reçu par SMS.
- **C.** Carte de professionnel de santé (CPS) et code personnel.
- **D.** Application e-CPS sur le téléphone et code.
- **E.** Mot de passe et question secrète (« nom de votre premier animal »).
- **F.** Mot de passe et validation sur une application d'authentification.

À vous de jouer – Questions

1. Citez les trois catégories de facteurs d'authentification avec un exemple. (3 pts)
2. Pour chaque moyen du document 1, dites s'il s'agit d'une double authentification et quels facteurs il utilise. (6 pts)
3. Répondez à l'inquiétude des professionnels en trois phrases. (3 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.16 – Le gestionnaire de mots de passe (14 points)

★★★☆☆ *Niveau 3 – analyse · durée conseillée : 15 min*

Mise en situation – Mise en situation

Une diététicienne d'un réseau de prévention de l'obésité de l'enfant (fictif) fait le point sur ses comptes : messagerie, logiciel du réseau, site de formation, banque, réseaux sociaux de la structure, outils de visioconférence, fournisseurs. Elle a **23 comptes** et seulement **4 mots de passe** différents ; **15 comptes** utilisent le même. L'équipe compte **9 personnes**.

Document 1 – L'offre (fictive, 2028)

Gestionnaire de mots de passe professionnel : **3 € par utilisateur et par mois**, coffre partagé pour les comptes de la structure, double authentification incluse, données chiffrées sur l'appareil de l'utilisateur.

À vous de jouer – Questions

1. Calculez la part de ses comptes qui partagent le même mot de passe. Expliquez le risque si un seul de ces 15 services est piraté. (3 pts)
2. Calculez le coût annuel du gestionnaire pour l'équipe et le coût par personne et par an. (3 pts)
3. Donnez trois avantages du gestionnaire et deux précautions à prendre. (5 pts)
4. Les comptes des réseaux sociaux de la structure sont partagés par trois personnes. Comment les gérer avec le gestionnaire ? (3 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.17 – Le compte « cuisine » (14 points)

★★★☆☆ *Niveau 3 – analyse · durée conseillée : 20 min*

Mise en situation – Mise en situation

Dans la cuisine d'une maison d'accueil spécialisée (fictive), les six agents se connectent au logiciel de restauration avec un compte unique « cuisine », dont le mot de passe est écrit sur le réfrigérateur. Un jour, la texture « hachée » d'une résidente a été remplacée par « normale » ; la résidente a fait une fausse route sans gravité.

À vous de jouer – Questions

1. Relevez les deux problèmes de sécurité et dites quels objectifs de sécurité sont atteints. (4 pts)
2. Expliquez pourquoi on ne peut pas savoir qui a modifié la texture. Pourquoi est-ce aussi un problème pour les agents ? (3 pts)
3. Proposez une organisation des comptes adaptée à une cuisine (gants, rapidité, poste partagé). (4 pts)
4. Proposez une mesure qui empêche qu'une texture soit modifiée sans contrôle. (3 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.18 – « Votre mot de passe a été divulgué » (16 points)

★★★☆☆ *Niveau 3 – analyse · durée conseillée : 20 min*

Mise en situation – Mise en situation

Une diététicienne d'un centre de dialyse (fictif) reçoit une alerte de son navigateur : « Le mot de passe que vous utilisez sur le site de recettes "Cuisinons léger" fait partie d'une fuite de données. » Elle utilise ce même mot de passe pour sa messagerie professionnelle, le logiciel de dialyse et le site de formation continue.

Document 1 – Deux messages reçus le lendemain

- Message 1 : « Cuisinons léger : suite à un incident, changez votre mot de passe en cliquant ici. »
- Message 2 (envoyé depuis l'adresse d'une collègue) : « Coucou, peux-tu regarder ce document sur les apports en potassium ? » avec un lien vers une page de connexion qui ressemble à celle de la messagerie.

À vous de jouer – Questions

1. Expliquez pourquoi la fuite d'un site de recettes met en danger les données des patients. (3 pts)

2. Listez, dans l'ordre, les actions de la diététicienne dans l'heure qui suit l'alerte. (5 pts)

3. Analysez les deux messages du document 1 : lequel est probablement piégé, et que peut-on supposer pour la collègue ? (4 pts)

4. Qui la diététicienne doit-elle prévenir, et faut-il envisager une notification à la CNIL ? (4 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Corrigés de la partie 3

Corrigé – Exercice 21.13

1. Légendes : 1 Longueur ; 2 Unicité ; 3 Gestionnaire ; 4 Double authentification ; 5 Comptes nominatifs ; 6 Secret.
2. **Faibles** : 1 (mot courant, année et point d'exclamation : schéma très prévisible) ; 2 (le plus utilisé au monde, trouvé immédiatement) ; 3 (prénom et date de naissance : faciles à trouver sur les réseaux sociaux) ; 4 (nom de la structure : premier essai d'un attaquant). **Solides** : 5 (phrase de passe de 7 mots sans lien entre eux) ; 6 (15 caractères variés, aléatoires).
3. Le **5** : il est très solide et **facile à retenir et à taper** ; le mot de passe maître est le seul que l'on doit retenir. Le 6 est solide mais difficile à mémoriser : on risque de l'écrire sur un papier. Le 6 convient à un compte enregistré **dans** le gestionnaire.

Corrigé – Exercice 21.14

1. Type 1 : 10 puissance 6 = **1 × 10 puissance 6**. Type 2 : 62 puissance 8 ≈ **2,18 × 10 puissance 14**. Type 3 : 94 puissance 10 ≈ **5,39 × 10 puissance 19**. Type 4 : 7 776 puissance 7 ≈ **1,72 × 10 puissance 27**.
2. Temps = combinaisons / 10 puissance 10. Type 1 : **un dix-millième de seconde**. Type 2 : 2,18 × 10 puissance 4 secondes, soit 21 834 s ≈ **6 heures**. Type 3 : 5,39 × 10 puissance 9 secondes ≈ 5,39 × 10 puissance 9 / 3,16 × 10 puissance 7 ≈ **171 ans**. Type 4 : 1,72 × 10 puissance 17 secondes ≈ **5,4 milliards d'années**.
3. Le code d'une carte bancaire n'est pas attaqué « hors ligne » : la carte se **bloque après 3 essais faux**. La protection vient de la **limite d'essais** et de la possession de la carte (deux facteurs), pas de la longueur du code.
4. Exemple : « Choisissez une **phrase de passe** d'au moins 7 mots au hasard, ou laissez le gestionnaire créer des mots de passe longs ; n'utilisez jamais le même mot de passe deux fois ; activez la double authentification partout où elle existe. » Ces calculs supposent un mot de passe **aléatoire** : un mot de passe construit avec un prénom est trouvé bien plus vite.

Corrigé – Exercice 21.15

1. Ce que je **sais** : mot de passe, code personnel. Ce que je **possède** : carte, téléphone, clé de sécurité. Ce que je **suis** : empreinte digitale, visage.
2. A : non (un seul facteur). B : **oui** (savoir + posséder le téléphone) ; le SMS est moins sûr qu'une application, car il peut être détourné. C : **oui** (posséder la carte + savoir le code). D : **oui** (posséder le téléphone avec l'application + savoir le code). E : **non** : la question secrète est un deuxième élément **de la même catégorie** (ce que je sais), souvent facile à trouver. F : **oui** (savoir + posséder le téléphone).
3. Exemple : « La validation prend quelques secondes, et l'appareil peut être reconnu pour plusieurs jours. Elle bloque la grande majorité des connexions faites avec un mot de passe volé, qui sont la première cause d'incident. Une seule boîte piratée peut envoyer de faux messages à tous nos patients et partenaires : quelques secondes valent bien cette protection. »

Corrigé – Exercice 21.16

1. 15 / 23 × 100 = **65,2 %** des comptes. Si l'un des 15 services est piraté, l'attaquant essaie le même identifiant et le même mot de passe **sur les autres services** (messagerie, logiciel du réseau, banque) : une seule fuite ouvre 15 portes.
2. 3 € × 9 personnes × 12 mois = **324 € par an**, soit 324 / 9 = **36 € par personne et par an**.
3. **Avantages** : des mots de passe longs et différents pour chaque service sans effort de mémoire ; remplissage automatique uniquement sur le **vrai site** (ce qui protège de certains faux sites) ; partage sécurisé des comptes de la structure ; alerte en cas de mot de passe faible, réutilisé ou divulgué.

Précautions : mot de passe maître très solide (phrase de passe) et double authentification ; ne jamais donner le mot de passe maître ; prévoir une procédure de récupération (si la personne oublie ou quitte la structure).

4. Les identifiants sont rangés dans un **coffre partagé** accessible aux trois personnes seulement ; quand l'une d'elles quitte la structure, on lui retire l'accès au coffre et on **change** le mot de passe. Mieux encore, quand le réseau social le permet, chaque personne reçoit un **accès nominatif** à la page de la structure.

Corrigé – Exercice 21.17

1. **Compte partagé** et **mot de passe affiché**. Objectifs atteints : **traçabilité** (on ne sait pas qui agit), **confidentialité** (toute personne qui passe dans la cuisine peut se connecter), **intégrité** (la texture a été modifiée sans contrôle).
2. Toutes les actions portent le nom « cuisine » : on ne peut pas savoir **qui** a modifié la texture, ni si c'est une erreur d'un agent ou une personne extérieure. Pour les agents, c'est un problème : **tous** sont soupçonnés, et aucun ne peut prouver qu'il n'a rien fait ; l'analyse de l'erreur (pour éviter qu'elle recommence) devient impossible.
3. **Un compte par agent**, avec un code court ou un **badge** à présenter (rapide avec des gants) ; verrouillage automatique du poste après quelques minutes ; droits limités : les agents **consultent** les textures, seule la diététicienne ou l'infirmière les **modifie** ; mot de passe jamais affiché.
4. Toute modification de régime ou de texture est faite par une personne habilitée et **validée** par une seconde (diététicienne ou médecin) ; elle est **historisée** (qui, quand, ancienne et nouvelle valeur) et apparaît en alerte sur la fiche de production du jour.

Corrigé – Exercice 21.18

1. Le même mot de passe ouvre la **messagerie professionnelle** et le **logiciel de dialyse** : un attaquant qui récupère la liste des comptes du site de recettes essaie ce couple identifiant et mot de passe sur les services professionnels. Il peut alors lire ou modifier des données de santé, ou envoyer de faux messages aux collègues et aux patients.
2. Dans l'ordre : (1) changer **tout de suite** le mot de passe de la messagerie et du logiciel de dialyse, depuis un poste sûr, avec des mots de passe **différents** ; (2) activer la double authentification si elle ne l'est pas ; (3) changer le mot de passe du site de formation et du site de recettes (ou supprimer ce compte) ; (4) vérifier la messagerie : règles de transfert ou de suppression ajoutées, messages envoyés inconnus ; (5) prévenir le référent sécurité ou le service informatique.
3. Le **message 2** est probablement piégé : un lien vers une **page de connexion** pour lire un document est un signe d'hameçonnage. La boîte de la collègue a sans doute été **piratée** (peut-être avec un mot de passe réutilisé, elle aussi). Le message 1 peut être vrai ou faux : on ne clique pas, on va soi-même sur le site en tapant l'adresse.
4. Elle prévient le **service informatique** (ou le référent sécurité) et le **délégué à la protection des données** ; elle prévient la collègue **par un autre moyen** (téléphone). Si l'examen montre qu'une personne non autorisée a **accédé** à la messagerie ou au logiciel contenant des données de patients, c'est une violation de données : le centre (responsable du traitement) la notifie à la CNIL dans les 72 heures si elle présente un risque.

Partie 4 – Les actions malveillantes

Objectifs – Objectifs de la partie

- Nommer les principales actions malveillantes et les reconnaître dans une situation.
- Repérer les signes d'un message piégé.
- Répondre à une tentative d'ingénierie sociale par téléphone.
- Mettre en place une procédure contre la fraude au virement.
- Analyser la chronologie d'une attaque par rançongiciel.
- Aider des patients à se protéger des arnaques qui les visent.

À connaître par cœur pour le bts – À connaître par cœur

- **Hameçonnage** : faux message (courriel, SMS, appel) qui imite un organisme connu pour voler un mot de passe, des coordonnées bancaires ou faire ouvrir une pièce jointe.
- **Rançongiciel** : programme qui chiffre les fichiers et demande une rançon ; souvent, les attaquants ont d'abord **copié** les données et menacent de les publier. On ne paie pas : rien ne garantit la récupération, et le paiement finance d'autres attaques.
- **Fraude au virement** (faux RIB, faux dirigeant) : une demande inhabituelle et urgente de paiement ; on vérifie **toujours par un autre canal** (numéro connu, pas celui du message).
- **Ingénierie sociale** : manipulation qui exploite la confiance, l'urgence, la peur ou l'envie d'aider.
- Signes d'un message piégé : **expéditeur** imité, **urgence**, **lien** trompeur, **pièce jointe** inattendue, **demande** d'information sensible, **forme** inhabituelle.

Exercice 21.19 – Reconnaître l'attaque (12 points)

★☆☆☆☆ *Niveau 1 – restitution · durée conseillée : 10 min*

Mise en situation – Mise en situation

La diététicienne d'un centre de lutte contre le cancer (fictif) prépare un quiz pour l'équipe de la cuisine et des soins de support.

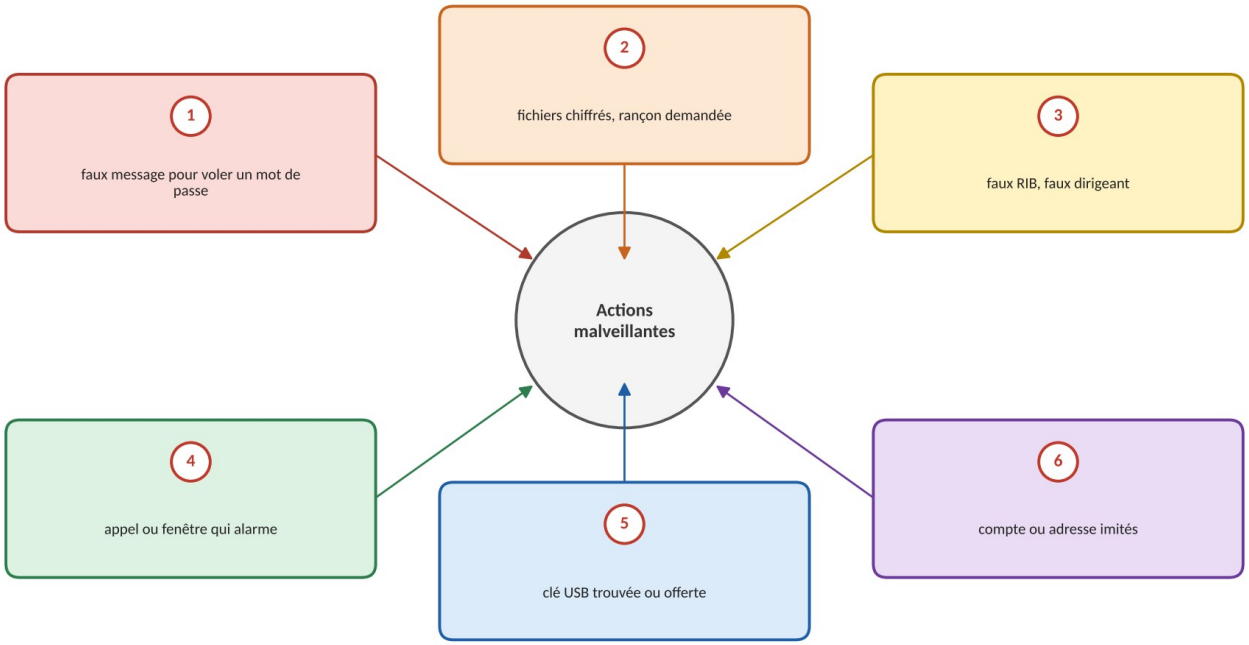


Figure 21.6 – Document 1 – Les principales actions malveillantes (schéma à légender)

Document 2 – Six situations

- **A.** Une fenêtre s'affiche : « Votre ordinateur est infecté, appelez immédiatement ce numéro. »
- **B.** Un courriel du « directeur », écrit depuis une adresse personnelle, demande un virement urgent et confidentiel.
- **C.** Tous les fichiers du serveur portent une nouvelle extension et un message demande un paiement en cryptomonnaie.
- **D.** Une clé USB est offerte sur le stand d'un faux laboratoire lors d'un congrès.
- **E.** Un SMS « Ameli : votre carte Vitale expire, mettez à jour vos informations » contient un lien.
- **F.** Un faux compte de réseau social au nom de la diététicienne propose des consultations payées d'avance.

À vous de jouer – Questions

1. Légendez les éléments numérotés 1 à 6 du document 1. (3 pts)

2. Associez chaque situation du document 2 à l'action malveillante correspondante. (6 pts)

3. Pour les situations A et C, donnez le premier geste à faire. (3 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.20 – Le bon de livraison piégé (14 points)

★★☆☆☆ *Niveau 2 – application · durée conseillée : 15 min*

Mise en situation – Mise en situation

Le magasinier de la cuisine centrale d'un groupement hospitalier (fictif) vous montre un courriel reçu à 7 h 52, alors qu'une livraison de produits laitiers est attendue.

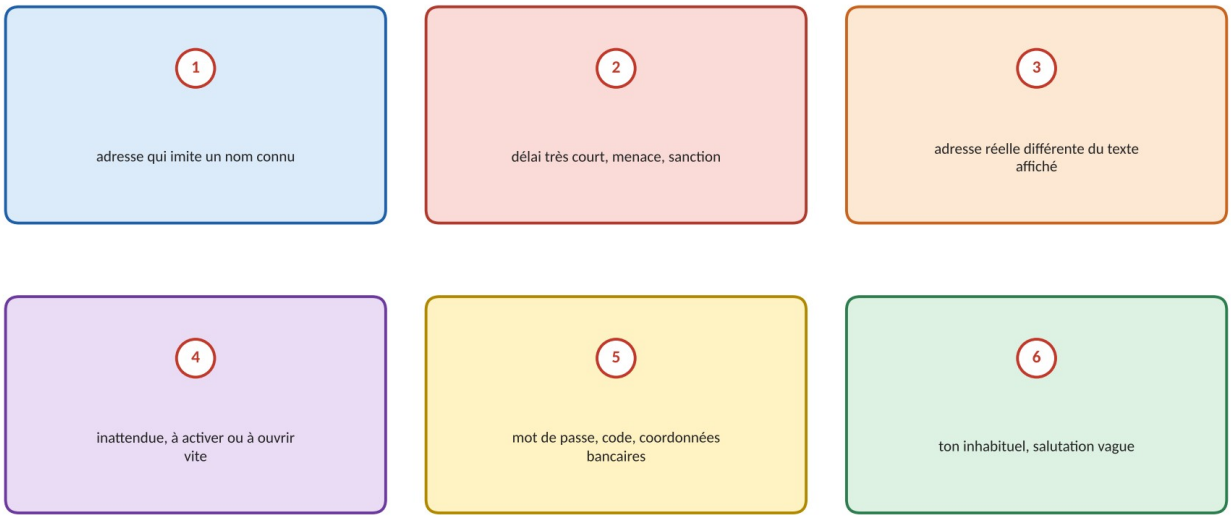


Figure 21.7 – Document 1 – Les signes d'un message piégé (schéma à légender)

Document 2 – Le message

De : Laiterie des Prés Verts <livraisons@laiterie-presverts-factures.com>

Objet : URGENT – Livraison bloquée – action requise avant 9 h 00

« Bonjour, votre livraison de ce jour ne pourra pas être déchargée car le bon de commande n° 2028-4471 comporte une erreur. Merci d'ouvrir le document joint (BonLivraison.zip) et d'activer le contenu pour le corriger. Sans réponse avant 9 h, la livraison sera annulée et facturée. Cordialement, le service logistique. »

L'adresse habituelle du fournisseur est « commandes@presverts.fr ».

À vous de jouer – Questions

1. Légendez les éléments numérotés 1 à 6 du document 1. (3 pts)
2. Relevez dans le document 2 au moins cinq signes qui doivent alerter, en les reliant au schéma. (5 pts)
3. Que doit faire le magasinier ? Et s'il a déjà ouvert la pièce jointe ? (4 pts)
4. Pourquoi ce message est-il bien construit pour une cuisine ? (2 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.21 – Un appel trop curieux (14 points)

★★☆☆☆ *Niveau 2 – application · durée conseillée : 15 min*

Mise en situation – Mise en situation

Vous êtes au secrétariat d'un service de portage de repas d'une mutuelle (fictif). Le téléphone sonne.

Document 1 – L'appel

« Bonjour, je suis le fils de Mme Perrin, je vis à l'étranger. Ma mère ne répond plus, je suis très inquiet. Pouvez-vous me donner son adresse exacte, le code de sa porte et me dire quel régime elle suit ? Je dois prévenir son médecin. Faites vite, s'il vous plaît, mon téléphone n'a presque plus de batterie. »

À vous de jouer – Questions

1. Relevez les procédés de manipulation utilisés dans cet appel. (4 pts)
2. Quelles informations ne doivent pas être données ? Pourquoi ? (3 pts)
3. Rédigez la réponse que vous faites au téléphone (6 lignes au plus), en restant aimable et en aidant vraiment si la personne est sincère. (5 pts)
4. Quelle règle écrite proposez-vous au service ? (2 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.22 – Le faux directeur (14 points)

★★★☆☆ *Niveau 3 – analyse · durée conseillée : 20 min*

Mise en situation – Mise en situation

Une association d'aide alimentaire (fictive) gère un budget de dons de 210 000 € par an. Un vendredi à 17 h 40, la comptable reçoit un message.

Document 1 – Le message

« De : Jean Barbier, président (j.barbier.president@courrier-perso.fr). Bonjour Sophie, je suis en réunion avec la préfecture et je ne peux pas téléphoner. Nous devons payer aujourd'hui un acompte de **18 400 €** à un nouveau fournisseur de compléments nutritionnels pour l'hiver. C'est confidentiel tant que le conseil d'administration n'est pas informé. Je compte sur vous, le RIB est joint. Merci de me confirmer le virement par retour. »

À vous de jouer – Questions

1. Relevez les signes de la fraude au faux dirigeant. (4 pts)
2. Calculez la part du budget annuel que représente ce virement. (1 pt)
3. Proposez une procédure écrite de paiement qui empêche cette fraude (au moins quatre règles). (5 pts)
4. Le virement est parti il y a une heure. Que faire, et dans quel ordre ? (4 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.23 – Chronologie d'un rançongiciel (16 points)

★★★☆☆ *Niveau 3 – analyse · durée conseillée : 25 min*

Mise en situation – Mise en situation

Un centre de santé (fictif), où travaillent deux diététiciennes, a subi un rançongiciel. Le rapport du prestataire retrace l'attaque.

Document 1 – La chronologie (données fictives)

- **3 mars** : une secrétaire saisit son mot de passe sur une fausse page de messagerie.
- **4 au 20 mars** : connexions inhabituelles la nuit, depuis l'étranger, sur sa messagerie puis sur le serveur ; copie de fichiers vers l'extérieur. Personne ne s'en aperçoit.
- **21 mars, 2 h** : chiffrement du serveur et des sauvegardes, qui étaient sur un disque relié au serveur. Message : « Payez 40 000 € ou vos dossiers seront publiés. »
- **21 mars, 8 h** : le centre découvre l'attaque.
- **22 au 30 mars** : reconstruction du système à partir d'une ancienne sauvegarde du 31 décembre trouvée chez le prestataire ; consultations des diététiciennes annulées pendant **9 jours ouvrés** (en moyenne **42 consultations** par jour pour les deux).

À vous de jouer – Questions

1. Calculez le temps passé par les attaquants dans le système avant le chiffrement. Que pouvaient-ils faire pendant ce temps ? (3 pts)

2. Calculez le nombre de consultations de diététique annulées. Quelles conséquences pour les patients ? (3 pts)

3. Quelles données ont été perdues entre le 31 décembre et le 21 mars ? Quelles sont les deux atteintes subies par les données (en plus de leur indisponibilité) ? (3 pts)

4. Le centre doit-il payer ? Argumentez. (3 pts)

5. Pour chaque étape de l'attaque, proposez une mesure qui l'aurait bloquée ou limitée. (4 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.24 – Les arnaques qui visent les patients (16 points)

★★★☆☆ *Niveau 3 – analyse · durée conseillée : 25 min*

Mise en situation – Mise en situation

Dans un programme d'éducation thérapeutique pour des personnes diabétiques (fictif), plusieurs patients parlent d'arnaques. La diététicienne fait passer un questionnaire anonyme à **120 patients**.

Document 1 – Les résultats (données fictives)

Question	Oui
Avez-vous reçu un message suspect (SMS ou courriel) ces six derniers mois ?	78
Parmi ceux qui en ont reçu : avez-vous cliqué sur le lien ?	9
Parmi ceux qui en ont reçu : avez-vous donné des informations bancaires ?	3

Exemples cités : « faux remboursement Ameli », « livraison gratuite de capteurs de glycémie », « cure naturelle qui remplace l'insuline ».

À vous de jouer – Questions

1. Calculez la part de patients ayant reçu un message suspect, et, parmi eux, la part ayant cliqué et la part ayant donné des informations bancaires. Calculez aussi ces deux dernières parts sur l'ensemble des 120 patients. (5 pts)
2. Expliquez pourquoi le message « cure naturelle qui remplace l'insuline » est dangereux pour la santé, au-delà de l'escroquerie. (3 pts)
3. Proposez une séance de 20 minutes à intégrer au programme : objectifs, déroulement, support. (5 pts)
4. Donnez la conduite à tenir à remettre aux patients qui ont donné leurs informations bancaires. (3 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Corrigés de la partie 4

Corrigé – Exercice 21.19

1. Légendes : 1 Hameçonnage ; 2 Rançongiciel ; 3 Fraude au virement ; 4 Faux support technique ; 5 Support piégé ; 6 Usurpation d'identité.
2. A : **faux support technique**. B : **fraude au virement** (faux dirigeant). C : **rançongiciel**. D : **support piégé**. E : **hameçonnage** (par SMS). F : **usurpation d'identité**.
3. A : ne pas appeler, **fermer le navigateur** (ou redémarrer) ; si la fenêtre ne se ferme pas, prévenir le référent ; ne jamais laisser un inconnu prendre la main à distance. C : **débrancher** le poste du réseau (câble, Wi-Fi) **sans l'éteindre**, puis alerter immédiatement le référent ou le prestataire.

Corrigé – Exercice 21.20

1. Légendes : 1 Expéditeur ; 2 Urgence ; 3 Lien ; 4 Pièce jointe ; 5 Demande ; 6 Forme.
2. **Expéditeur** : domaine « laiterie-presverts-factures.com » au lieu de « presverts.fr ». **Urgence** : « URGENT », « avant 9 h 00 ». **Menace** : livraison annulée et facturée. **Pièce jointe** : fichier compressé « .zip » inattendu. **Demande** : « activer le contenu », ce qui lance souvent un programme malveillant. **Forme** : signature vague (« le service logistique »), pas de nom de contact habituel.
3. Ne pas ouvrir la pièce jointe ; **appeler le fournisseur** au numéro habituel (pas celui du message) ; transférer le message au référent ou au service informatique, puis le supprimer. S'il l'a déjà ouverte : **débrancher le poste du réseau** sans l'éteindre, prévenir immédiatement le service informatique, ne plus utiliser le poste, noter l'heure.
4. Il arrive **à l'heure des livraisons**, imite un **vrai fournisseur**, utilise un vocabulaire de cuisine (bon de commande, déchargement) et joue sur la peur de manquer de produits pour le service des repas.

Corrigé – Exercice 21.21

1. **Urgence** (« faites vite », batterie faible) ; **émotion** (inquiétude pour une mère âgée) ; **autorité ou légitimité** apparente (fils, médecin) ; **éloignement** qui empêche de vérifier (à l'étranger) ; demande d'informations **sensibles** en une fois.
2. Le **code de la porte** et l'adresse exacte (risque de vol ou d'agression d'une personne âgée seule) et le **régime** (donnée de santé couverte par le secret). Le service ne peut pas vérifier l'identité de l'appelant au téléphone.
3. Exemple : « Je comprends votre inquiétude. Je ne peux pas donner d'informations par téléphone, c'est une règle pour protéger tous nos bénéficiaires. Je vais tout de suite demander au livreur de passer chez votre mère, ou contacter la personne de confiance inscrite dans son dossier. Donnez-moi votre nom et votre numéro : nous vous rappelons dès que nous avons de ses nouvelles. Si vous pensez qu'elle est en danger, appelez le 112. »
4. « Aucune information sur un bénéficiaire (adresse, code, santé, absence) n'est donnée par téléphone. On propose de rappeler la personne à un numéro **déjà connu** dans le dossier, on agit soi-même si une inquiétude est réelle, et on signale tout appel suspect au responsable. »

Corrigé – Exercice 21.22

1. Adresse **personnelle** inhabituelle ; **urgence** (vendredi 17 h 40, « aujourd'hui ») ; **impossibilité de téléphoner** ; **confidentialité** demandée (« le conseil n'est pas informé ») ; **nouveau fournisseur** et RIB joint ; flatterie (« je compte sur vous »).
2. 18 400 / 210 000 × 100 = **8,8 %** du budget annuel.
3. Exemple : (1) tout nouveau RIB ou changement de RIB est **vérifié par téléphone** au numéro connu du fournisseur ; (2) tout paiement au-dessus de 1 500 € demande **deux signatures** ; (3) aucune demande de

paiement n'est acceptée par message seul, même du président : confirmation orale par un **numéro connu** ; (4) un paiement à un nouveau fournisseur suppose un bon de commande validé ; (5) **aucun paiement** urgent le vendredi soir sans double vérification ; (6) la procédure est connue du président, qui s'engage à ne jamais la contourner.

4. (1) Appeler **immédiatement la banque** pour demander le rappel ou le blocage du virement (plus on agit vite, plus il y a de chances de récupérer les fonds) ; (2) prévenir le président par un numéro connu ; (3) **porter plainte** (police, gendarmerie), avec le message et le RIB ; (4) signaler sur **17Cyber** ou *cybermalveillance.gouv.fr* ; (5) vérifier si la messagerie de la comptable ou du président a été piratée ; (6) informer le conseil d'administration et revoir la procédure.

Corrigé – Exercice 21.23

1. Du 3 mars au 21 mars : **18 jours**. Pendant ce temps, les attaquants ont **exploré** le système, récupéré d'autres comptes, **copié** les données (dossiers, données de santé) et repéré les sauvegardes pour les chiffrer aussi.
2. 42 × 9 = **378 consultations** annulées. Conséquences : retard de prise en charge (dénutrition, diabète, insuffisance rénale), patients perdus de vue, stress, perte de recettes pour le centre ; il faut prévoir une liste papier des rendez-vous et prévenir les patients prioritaires.
3. Perdues : tous les dossiers créés ou modifiés **entre le 31 décembre et le 21 mars** (près de trois mois de bilans, de courriers et de rendez-vous). En plus de l'indisponibilité, les données ont subi une atteinte à la **confidentialité** (copie et menace de publication) et une **perte définitive** (environ trois mois de dossiers).
4. **Non**. Payer ne garantit ni la remise des clés, ni l'effacement des données copiées ; cela finance d'autres attaques et désigne le centre comme une cible qui paie. Les autorités (ANSSI, *cybermalveillance.gouv.fr*) recommandent de ne pas payer, de porter plainte et de se faire accompagner.
5. Faux message : **sensibilisation** et **double authentification** (le mot de passe seul n'aurait pas suffi). Connexions de nuit depuis l'étranger : **surveillance des connexions** et alertes. Copie de fichiers : **droits limités** et chiffrement des données. Chiffrement des sauvegardes : **sauvegarde déconnectée** ou externalisée, testée. Reprise lente : **plan de continuité** (liste papier des rendez-vous, procédure dégradée) et exercices.

Corrigé – Exercice 21.24

1. Reçu un message suspect : 78 / 120 = **65,0 %**. Parmi eux : cliqué 9 / 78 = **11,5 %** ; données bancaires 3 / 78 = **3,8 %**. Sur l'ensemble : cliqué 9 / 120 = **7,5 %** ; données bancaires 3 / 120 = **2,5 %**. Le questionnaire est déclaratif : certains patients ne savent pas qu'ils ont reçu un message piégé, ou n'osent pas dire qu'ils ont cliqué, malgré l'anonymat.
2. Un patient qui croit la promesse peut **arrêter son insuline** : risque d'hyperglycémie grave et d'acidocétose, qui peut être mortelle. L'arnaque fait perdre de l'argent **et** met la vie en danger ; elle exploite la lassitude du traitement.
3. Exemple : **objectifs** : chaque patient cite trois signes d'un message piégé et sait à qui demander conseil avant de changer un traitement. **Déroulement** : 5 min de recueil d'exemples vécus ; 10 min de jeu « vrai ou faux message » sur de grandes cartes (faux SMS Ameli, fausse promesse de cure, vrai rappel de rendez-vous) ; 5 min de synthèse : « je ne clique pas, je vérifie en appelant moi-même, je ne change jamais mon traitement sans mon médecin ». **Support** : fiche en gros caractères avec les numéros utiles et l'adresse *cybermalveillance.gouv.fr*.
4. Appeler **tout de suite la banque** pour faire opposition à la carte ; surveiller les comptes ; porter plainte ; signaler le message (17Cyber, *cybermalveillance.gouv.fr*) ; changer le mot de passe du compte Ameli si des identifiants ont été donnés ; se méfier des appels qui suivent (faux conseillers bancaires).

Partie 5 – Réagir à un incident et assurer la continuité

Objectifs – Objectifs de la partie

- Ordonner les étapes de la réaction à un incident.
- Calculer le délai de notification d'une violation de données.
- Rédiger une fiche réflexe pour une équipe.
- Organiser un mode dégradé pour une activité vitale (repas, soins).
- Comparer le coût d'une panne et le coût d'une mesure de continuité.
- Analyser un retour d'expérience avec des indicateurs de délai.

À connaître par cœur pour le bts – À connaître par cœur

- Réagir : **isoler** (débrancher du réseau, sans éteindre) ; **alerter** (référent, direction, prestataire) ; **préserver** les preuves (noter les faits, l'heure, garder les messages) ; **déclarer** (CNIL si violation de données avec risque, CERT Santé pour les structures de santé, plainte) ; **rétablir** et **apprendre** (restaurer, changer les accès, retour d'expérience).
- La notification à la CNIL se fait dans les **72 heures** après que le **responsable du traitement** a eu connaissance de la violation ; une notification incomplète peut être complétée ensuite. Le sous-traitant informe le responsable dans les meilleurs délais.
- La **continuité** : repérer les activités vitales, prévoir un **mode dégradé** sans informatique, préparer les listes et les fiches réflexes, **s'exercer** chaque année, améliorer.
- Un bon retour d'expérience cherche **les causes**, pas un coupable.

Exercice 21.25 – Les étapes de la réaction (10 points)

★☆☆☆☆ *Niveau 1 – restitution · durée conseillée : 10 min*

Mise en situation – Mise en situation

Dans un institut médico-éducatif (fictif), un écran affiche un message de rançon. L'éducatrice qui l'a vu vous demande ce qu'il faut faire.

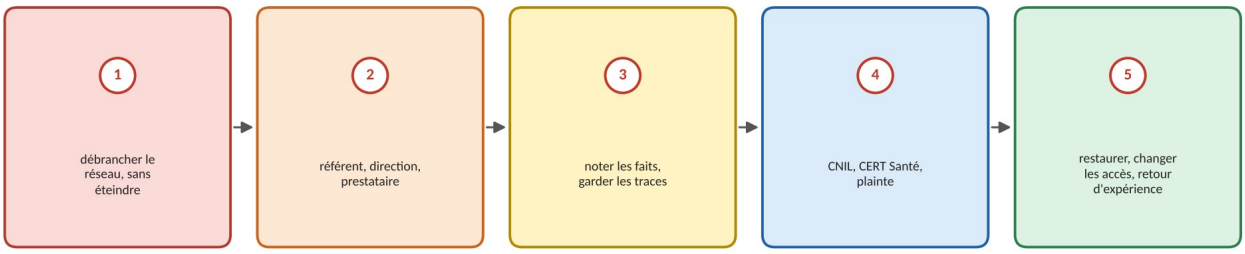


Figure 21.8 – Document 1 – Réagir à un incident de cybersécurité (schéma à légender)

Document 2 – Les actions (dans le désordre)

- **A.** Prévenir le directeur et le prestataire informatique.
- **B.** Débrancher le câble réseau et couper le Wi-Fi du poste.
- **C.** Restaurer les données à partir d'une sauvegarde saine.
- **D.** Photographier l'écran et noter l'heure.
- **E.** Notifier la violation à la CNIL et porter plainte.
- **F.** Organiser une réunion de retour d'expérience.

À vous de jouer – Questions

1. Légendez les éléments numérotés 1 à 5 du document 1. (2,5 pts)

2. Classez les actions du document 2 dans l'ordre. (3 pts)

3. Pourquoi ne faut-il pas éteindre l'ordinateur ? Pourquoi ne faut-il pas payer ? (2,5 pts)

4. Citez deux actions qu'il ne faut surtout pas faire. (2 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.26 – Le délai de 72 heures (12 points)

★★☆☆☆ *Niveau 2 – application · durée conseillée : 15 min*

Mise en situation – Mise en situation

Vous aidez le délégué à la protection des données d'un groupement de santé (fictif) à calculer des délais.

Document 1 – Trois situations (fictives)

- **Situation 1** : une tablette contenant les bilans nutritionnels de 63 patients, non chiffrée, est volée. La diététicienne s'en aperçoit et prévient la direction le **vendredi à 16 h 30**.
- **Situation 2** : le prestataire de la messagerie a subi une intrusion le **lundi à 3 h** ; il ne s'en rend compte que le **mardi à 18 h** et prévient le groupement le **mercredi à 10 h**.
- **Situation 3** : une diététicienne envoie par erreur le compte rendu d'un patient à un autre patient, le **jeudi à 11 h** ; le destinataire la prévient le jour même et affirme avoir supprimé le message.

À vous de jouer – Questions

1. Pour la situation 1, calculez l'heure limite de notification à la CNIL. Le week-end change-t-il le délai ? (3 pts)
2. Pour la situation 2, qui notifie la CNIL et à partir de quand court le délai ? Calculez l'heure limite. (4 pts)
3. Pour la situation 3, une notification est-elle nécessaire ? Que faut-il faire dans tous les cas ? (3 pts)
4. Dans quel cas faut-il aussi informer les personnes concernées ? (2 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.27 – La fiche réflexe de la cuisine (14 points)

★★★☆☆ *Niveau 3 – analyse · durée conseillée : 20 min*

Mise en situation – Mise en situation

La cuisine centrale d'un syndicat de restauration collective (fictif) produit 3 400 repas par jour pour les écoles, deux EHPAD et le portage. Les agents arrivent à 5 h 30 ; le responsable informatique n'arrive qu'à 8 h 30. La diététicienne vous demande une fiche réflexe à afficher près des postes.

À vous de jouer – Questions

1. Listez les informations qui doivent figurer sur la fiche (au moins six). (4 pts)
2. Rédigez la fiche réflexe en une page au plus, avec des phrases courtes à l'impératif, pour la situation « un poste affiche un message de rançon ou ne répond plus de façon anormale ». (6 pts)
3. Expliquez comment vous vérifiez que les agents savent appliquer la fiche. (2 pts)
4. Pourquoi la fiche doit-elle exister aussi sur papier ? (2 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.28 – Le mode dégradé des repas (14 points)

★★★☆☆ *Niveau 3 – analyse · durée conseillée : 20 min*

Mise en situation – Mise en situation

Dans un hôpital de 280 lits (fictif), les repas sont commandés chaque jour par les soignants dans le dossier du patient ; la cuisine reçoit automatiquement les régimes, les textures et les allergies. La direction demande au service diététique de préparer le mode dégradé en cas de panne de plusieurs jours.

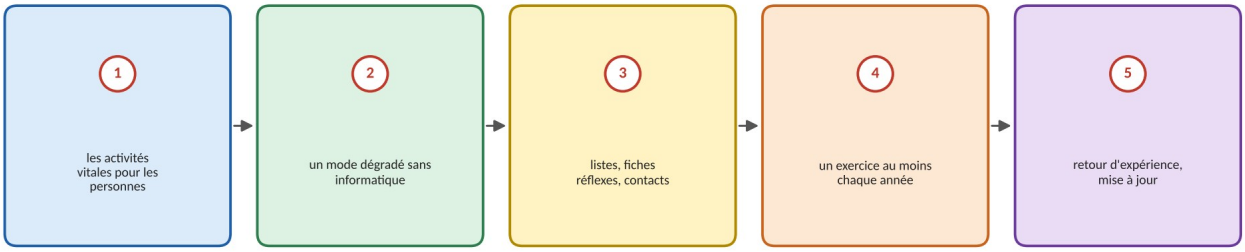


Figure 21.9 – Document 1 – Préparer la continuité de l'activité (schéma à légender)

À vous de jouer – Questions

1. Légendez les éléments numérotés 1 à 5 du document 1. (2,5 pts)
2. Pour la restauration des patients, citez les informations vitales et dites pourquoi. (3 pts)
3. Décrivez le mode dégradé : documents papier, circuit des commandes, contrôle des plateaux, responsabilités. (5,5 pts)
4. Proposez l'organisation d'un exercice annuel (durée, scénario, indicateurs). (3 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.29 – Combien coûte une journée en mode dégradé ? (14 points)

★★★☆☆ *Niveau 3 – analyse · durée conseillée : 20 min*

Mise en situation – Mise en situation

La cuisine commune de trois EHPAD (fictive) produit **900 repas par jour**. La direction hésite à payer une solution de continuité.

Document 1 – Les données (fictives)

- Une journée en mode dégradé coûte : 3 agents × 4 heures supplémentaires à **27 €** l'heure ; un surcoût de denrées de **0,60 € par repas** (portions de secours, produits jetés) ; **180 €** d'impressions et d'achats d'urgence.
- Hypothèse : sans mesure, une panne de **3 jours** tous les **2 ans**.
- Solution de continuité (export automatique quotidien des régimes, poste de secours, contrat de rétablissement) : **1 200 € par an** ; la panne serait réduite à **une demi-journée** tous les 2 ans.

À vous de jouer – Questions

1. Calculez le coût d'une journée en mode dégradé. (3 pts)

2. Calculez le coût moyen annuel des pannes sans la solution, puis avec la solution. (4 pts)

3. Faites le bilan financier annuel de la solution. Concluez. (3 pts)

4. Citez deux bénéfices de la solution qui ne sont pas comptés en euros. (2 pts)

5. Quelle limite a ce calcul ? (2 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.30 – Le retour d'expérience (16 points)

★★★★☆ *Niveau 4 – situation professionnelle · durée conseillée : 30 min*

Mise en situation – Mise en situation

Dans le service diététique d'un centre hospitalier (fictif), la messagerie d'une diététicienne a été piratée. Le responsable de la sécurité vous demande de préparer le retour d'expérience.

Document 1 – La chronologie (fictive)

- **Lundi 9 h 10** : la diététicienne clique sur un lien « Votre boîte est pleine » et saisit son mot de passe à 9 h 12.
- **Lundi 9 h 30 à mardi 13 h** : 412 messages piégés partent de sa boîte vers ses contacts ; une règle de transfert envoie ses nouveaux messages vers une adresse inconnue.
- **Mardi 14 h** : un médecin d'un autre hôpital appelle : « Je reçois des messages bizarres de votre part. »
- **Mardi 14 h 40** : le service informatique est prévenu.
- **Mardi 15 h 05** : mot de passe changé, sessions fermées, règle de transfert supprimée.
- **Mercredi 11 h** : l'analyse montre que **37 messages** contenant des comptes rendus de consultation ont été transférés.
- **Vendredi 10 h** : notification à la CNIL par l'hôpital.

À vous de jouer – Questions

1. Calculez le délai de détection (de la saisie du mot de passe au premier signalement), le délai d'alerte du service informatique et le délai de confinement. (4 pts)
2. Le délai de notification à la CNIL est-il respecté ? Justifiez par un calcul. (3 pts)
3. Faut-il informer les patients des 37 comptes rendus ? Justifiez. (3 pts)
4. Proposez trois mesures pour réduire chacun des délais calculés à la question 1. (3 pts)
5. Rédigez deux règles de conduite du retour d'expérience pour qu'il soit utile et ne culpabilise pas. (3 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Corrigés de la partie 5

Corrigé – Exercice 21.25

1. Légendes : 1 Isoler ; 2 Alerter ; 3 Préserver ; 4 Déclarer ; 5 Rétablir et apprendre.
2. Ordre : **B** (isoler), **A** (alerter), **D** (préserver), **E** (déclarer), **C** (rétablir), **F** (apprendre). D peut se faire en même temps que A, par une autre personne.
3. Éteindre efface des **traces** utiles dans la mémoire de l'ordinateur et peut empêcher de comprendre l'attaque ou de récupérer des données ; on **débranche** le réseau pour arrêter la propagation. Payer ne garantit rien, finance les attaquants et fait de la structure une cible.
4. Exemples : brancher une clé USB ou un disque de sauvegarde sur le poste infecté ; essayer de « réparer » seul ou supprimer des fichiers ; contacter les attaquants ; continuer à utiliser le poste ; prévenir tout le monde par la messagerie peut-être piratée.

Corrigé – Exercice 21.26

1. Vendredi 16 h 30 + 72 heures = **lundi 16 h 30**. Le week-end **ne prolonge pas** le délai : les 72 heures sont des heures calendaires. Si l'analyse n'est pas terminée, on fait une notification initiale, complétée ensuite.
2. C'est le **groupement** (responsable du traitement) qui notifie la CNIL. Le délai court à partir du moment **où il a connaissance** de la violation : mercredi 10 h. Heure limite : **samedi 10 h**. Le prestataire (sous-traitant) devait l'informer « dans les meilleurs délais » : de mardi 18 h à mercredi 10 h, il a mis 16 heures ; le contrat peut fixer un délai plus court.
3. C'est une **violation de données** (divulgation à une personne non autorisée) : elle est **inscrite au registre** des violations dans tous les cas. Si le destinataire est de bonne foi, a confirmé la suppression et que le compte rendu ne contient pas d'information sensible au-delà de la consultation, le risque peut être jugé faible : la notification n'est alors pas obligatoire. L'analyse est faite avec le DPO et **documentée** ; on prévient le patient concerné si le risque est réel, et on prend une mesure (vérification du destinataire, messagerie sécurisée).
4. Quand la violation présente un **risque élevé** pour les droits et libertés des personnes (article 34 du RGPD) : par exemple, données de santé non chiffrées dans la nature (situation 1), ou données publiées.

Corrigé – Exercice 21.27

1. Le titre clair ; les **signes** qui doivent alerter ; les **premiers gestes** (débrancher le réseau, ne pas éteindre) ; ce qu'il ne faut **pas** faire ; les **numéros** à appeler, dans l'ordre (cadre d'astreinte, prestataire, direction) ; ce qu'il faut **noter** (heure, message, poste) ; comment **continuer la production** (classeur papier du mode dégradé) ; la date de mise à jour de la fiche.
2. Exemple :

Fiche réflexe – « Message de rançon ou poste qui ne répond plus »

1. Ne touchez plus au clavier. N'éteignez pas le poste. **2. Débranchez** le câble réseau (prise bleue) et coupez le Wi-Fi. **3. Ne branchez** ni clé USB ni disque. **4. Notez** l'heure, le numéro du poste et le message (photo avec un téléphone). **5. Appelez** le cadre d'astreinte : [numéro]. Il prévient le prestataire et la direction. **6. Ne prévenez pas** par courriel : téléphonez. **7. Ouvrez le classeur rouge** « Mode dégradé » : liste des régimes du vendredi, bons de production papier. **8. Vérifiez** chaque régime et chaque texture à deux avant le départ des repas. Fiche mise à jour le [date].

3. Par un **exercice** court lors d'une réunion d'équipe (simulation : « ce poste affiche un message de rançon, que faites-vous ? »), en observant si les gestes sont faits dans l'ordre ; en vérifiant que le classeur rouge est à jour ; en interrogeant les agents des équipes du matin.
4. Si l'informatique est en panne ou attaquée, une fiche **seulement numérique** est inaccessible au moment où l'on en a besoin. Le papier est aussi plus rapide à 5 h 30, sans le responsable informatique.

Corrigé – Exercice 21.28

1. Légendes : 1 Repérer ; 2 Prévoir ; 3 Préparer ; 4 S'exercer ; 5 Améliorer.
2. Pour chaque patient : identité et chambre, **régime**, **texture**, **allergies**, repas à jeun ou interdits (examens), compléments nutritionnels prescrits. Une erreur peut provoquer une réaction allergique grave, une fausse route, un déséquilibre du diabète, une décompensation cardiaque, ou fausser un examen.
3. **Documents** : liste des patients par service avec régime, texture et allergies, **imprimée chaque jour** à heure fixe (ou export automatique chiffré) ; bons de commande papier pré-imprimés ; étiquettes de couleur pour les plateaux. **Circuit** : l'infirmière complète le bon papier et le porte (ou le dicte au téléphone, avec relecture) à la cuisine à heure fixe ; la diététicienne centralise et corrige. **Contrôle** : double vérification des plateaux adaptés (agent et diététicienne), étiquette au nom du patient. **Responsabilités** : cadre de santé (bons du service), diététicienne (validation des régimes), chef de cuisine (production), direction (déclenchement et fin du mode dégradé).
4. **Une demi-journée** par an, en semaine, sur un service volontaire puis sur tout l'hôpital ; scénario : « logiciel de dossier patient indisponible à 6 h » ; indicateurs : délai pour produire la liste papier, nombre de bons reçus à l'heure, nombre d'erreurs de plateau, avis des agents ; retour d'expérience écrit et mise à jour de la procédure.

Corrigé – Exercice 21.29

1. Heures supplémentaires : 3 × 4 × 27 = 324 € ; denrées : 900 × 0,60 = 540 € ; impressions et achats : 180 €. Total : **1 044 € par journée**.
2. **Sans la solution** : 3 jours tous les 2 ans, soit 3 × 1 044 / 2 = **1 566 € par an** en moyenne. **Avec la solution** : une demi-journée tous les 2 ans, soit 0,5 × 1 044 / 2 = **261 € par an**.
3. Économie sur les pannes : 1 566 – 261 = 1 305 € par an ; coût de la solution : 1 200 €. Bilan : **+ 105 € par an**. La solution est **à peu près rentable** à elle seule sur le plan financier ; elle est surtout justifiée par la sécurité des résidents.
4. Moins d'**erreurs de régime ou de texture** (sécurité des résidents) ; moins de **stress** et de fatigue des agents ; meilleure image auprès des familles ; respect des obligations de sécurité.
5. Le calcul repose sur une **hypothèse** de fréquence et de durée de panne, très incertaine : une attaque par rançongiciel peut durer des semaines (le gain serait alors bien plus grand) ; il ne compte pas les conséquences pour la santé des résidents ni le temps de reconstruction.

Corrigé – Exercice 21.30

1. **Détection** : de lundi 9 h 12 à mardi 14 h = **28 h 48 min**. **Alerte** du service informatique : de 14 h à 14 h 40 = **40 min**. **Confinement** : de 14 h 40 à 15 h 05 = **25 min**.
2. L'hôpital a eu connaissance de la violation mardi à **14 h 40** au plus tôt (on peut aussi retenir mercredi 11 h, quand la fuite des comptes rendus est établie). De mardi 14 h 40 à vendredi 10 h : 67 h 20 min, soit **moins de 72 heures** : le délai est respecté dans les deux cas.
3. Oui, très probablement : 37 comptes rendus de consultation (données de santé) sont partis vers une adresse **inconnue**, utilisée par des attaquants : le **risque est élevé** (article 34). Les patients sont informés simplement : ce qui s'est passé, les données concernées, ce que l'hôpital a fait, à qui s'adresser, et les précautions (méfiance face aux messages ou appels qui citeraient leur consultation).
4. **Détection** : alerte automatique en cas d'envoi massif ou de nouvelle règle de transfert ; double authentification (qui aurait sans doute empêché la connexion). **Alerte** : un numéro unique et connu de tous pour signaler un problème, et un réflexe enseigné : « au moindre doute, j'appelle ». **Confinement** : procédure écrite (changer le mot de passe, fermer les sessions, vérifier les règles), applicable aussi par l'astreinte.
5. « On cherche **ce qui a permis** l'incident (outils, organisation, formation), pas un coupable : la personne qui

> a cliqué participe et n'est pas sanctionnée. » ; « Chaque constat aboutit à une **action datée**, avec un responsable, et on vérifie trois mois plus tard qu'elle est faite. »

Partie 6 – Sensibiliser l'équipe et mesurer les progrès

Objectifs – Objectifs de la partie

- Construire une action de sensibilisation en partant d'un constat.
- Rédiger des objectifs mesurables.
- Calculer et comparer des taux de clic, de saisie et de signalement.
- Calculer un intervalle de confiance et en vérifier les conditions.
- Exploiter un questionnaire de connaissances avant et après une formation.
- Concevoir une séance courte et suivre un tableau de bord.

À connaître par cœur pour le bts – À connaître par cœur

- Une sensibilisation part d'un **constat** (incidents, pratiques observées, mesure de départ), fixe des **objectifs** de comportement chiffrés, utilise des **exemples du service**, entraîne (exercice simulé) et **mesure** avec les mêmes indicateurs.
- Un exercice d'**hameçonnage simulé** se prépare avec la direction, après information du personnel et de ses représentants ; les résultats sont présentés **sans nom** et ne servent jamais à sanctionner.
- Indicateurs : taux de **clic**, taux de **saisie** d'identifiants, taux de **signalement** (le plus encourageant à suivre).
- Intervalle de confiance à 95 % d'une proportion p mesurée sur n personnes : $p \pm 1{,}96 \times \sqrt{p \times (1 - p) / n}$, si $n \geq 30$, $n \times p \geq 5$ et $n \times (1 - p) \geq 5$.
- Une séance courte (10 à 30 minutes), répétée, est plus efficace qu'une longue formation unique.

Exercice 21.31 – Construire une sensibilisation (12 points)

★☆☆☆☆ *Niveau 1 – restitution · durée conseillée : 10 min*

Mise en situation – Mise en situation

La responsable d'un service de soins à domicile (fictif) veut « faire une formation sur la cybersécurité » après deux incidents. Vous l'aidez à construire l'action.

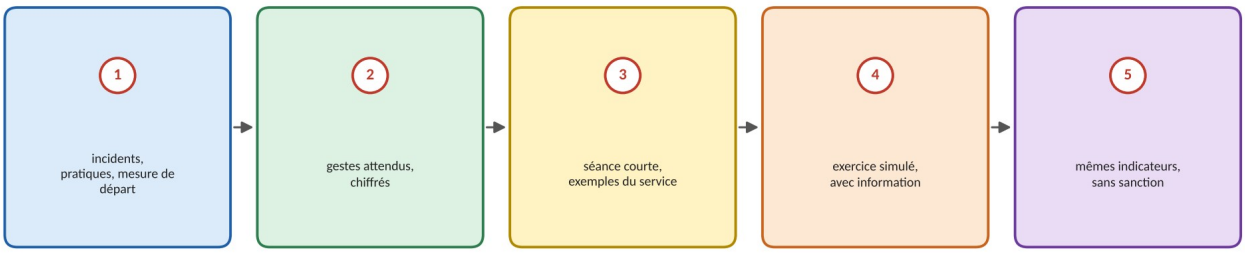


Figure 21.10 – Document 1 – Construire une action de sensibilisation (schéma à légender)

Document 2 – Trois objectifs proposés

- **A.** « Que l'équipe soit sensibilisée à la cybersécurité. »
- **B.** « Dans six mois, au moins 60 % des agents signalent le faux message d'un exercice simulé au référent. »
- **C.** « Que plus personne ne clique jamais sur un lien. »

À vous de jouer – Questions

1. Légendez les éléments numérotés 1 à 5 du document 1. (2,5 pts)

2. Dites quel objectif du document 2 est bien formulé et corrigez les deux autres. (4,5 pts)

3. Proposez deux autres objectifs mesurables pour cette équipe. (3 pts)

4. Pourquoi faut-il mesurer avant la séance ? (2 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.32 – Résultats d'un hameçonnage simulé (14 points)

★★☆☆☆ *Niveau 2 – application · durée conseillée : 15 min*

Mise en situation – Mise en situation

Un centre hospitalier (fictif) a organisé un exercice d'hameçonnage simulé dans trois services, après information du personnel. Vous exploitez les résultats.

Document 1 – Les résultats (données fictives)

Service	Agents	Clics	Saisies d'identifiants	Signalements
Restauration	42	14	6	5
Diététique	8	2	0	3
Administration	30	9	4	7

À vous de jouer – Questions

1. Calculez, pour chaque service et pour l'ensemble, les taux de clic, de saisie et de signalement (en %, à 0,1 près). (6 pts)
2. Comparez les services. Peut-on conclure que le service diététique est le plus prudent ? (3 pts)
3. Citez trois conditions pour qu'un exercice simulé soit acceptable sur le plan éthique et légal. (3 pts)
4. Comment présenter ces résultats à l'équipe de restauration ? (2 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.33 – Le progrès est-il réel ? (14 points)

★★★☆☆ *Niveau 3 – analyse · durée conseillée : 20 min*

Mise en situation – Mise en situation

Après l'exercice de l'exercice 21.32 (25 clics sur 80 agents), le centre hospitalier organise des « quarts d'heure sécurité ». Trois mois plus tard, un second exercice donne **12 clics sur 80 agents**.

À vous de jouer – Questions

1. Calculez le taux de clic de chaque exercice et vérifiez les conditions de calcul d'un intervalle de confiance. (4 pts)
2. Calculez l'intervalle de confiance à 95 % de chaque taux (à 0,1 point près). (4 pts)
3. Les deux intervalles se chevauchent-ils ? Que peut-on en dire prudemment ? (3 pts)
4. Citez trois raisons, autres que les séances, qui peuvent expliquer la baisse du taux de clic. (3 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.34 – Le questionnaire avant et après (14 points)

★★★☆☆ *Niveau 3 – analyse · durée conseillée : 20 min*

Mise en situation – Mise en situation

Vous avez animé une séance de 30 minutes pour les **12 agents** de la cuisine d'un EHPAD (fictif). Chacun a répondu au même questionnaire de 10 questions avant et après la séance (un point par bonne réponse), avec un code personnel à la place du nom.

Document 1 – Les scores sur 10 (données fictives)

Agent	A1	A2	A3	A4	A5	A6	A7	A8	A9	A10	A11	A12
Avant	4	6	5	3	7	5	6	4	8	5	6	3
Après	7	8	7	6	9	7	8	6	9	8	8	5

À vous de jouer – Questions

1. Calculez la moyenne avant et après, et le gain moyen. (4 pts)
2. Calculez le nombre et la part d'agents ayant au moins 7 sur 10, avant et après. (3 pts)
3. Quel agent progresse le moins ? Que lui proposez-vous, sans le désigner ? (3 pts)
4. Le questionnaire mesure-t-il un changement de comportement ? Proposez un indicateur de comportement. (4 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.35 – Le quart d'heure sécurité en cuisine (16 points)

★★★★☆ *Niveau 4 – situation professionnelle · durée conseillée : 30 min*

Mise en situation – Mise en situation

La cuisine centrale d'un groupe de cliniques (fictif) emploie 28 agents, en horaires décalés. Ils utilisent deux postes partagés (réception des marchandises, fiches de production) et leur téléphone personnel pour le groupe de messagerie de l'équipe. Il n'est pas possible de les réunir plus de 15 minutes, debout, avant le service.

À vous de jouer – Questions

1. Choisissez trois messages clés adaptés à cette équipe et justifiez votre choix. (4 pts)
2. Construisez le déroulé minuté d'un quart d'heure, avec un support adapté à une cuisine. (6 pts)
3. Comment toucher les agents des différentes équipes et ceux qui ne lisent pas facilement le français ? (3 pts)
4. Le groupe de messagerie de l'équipe sur les téléphones personnels sert aussi à envoyer des photos de la liste des régimes. Que proposez-vous ? (3 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.36 – Le tableau de bord de l'année (16 points)

★★★★☆ *Niveau 4 – situation professionnelle · durée conseillée : 30 min*

Mise en situation – Mise en situation

Un centre de rééducation (fictif) de **80 agents** suit chaque trimestre des indicateurs de sécurité depuis le lancement de son plan de sensibilisation.

Document 1 – Les indicateurs (données fictives)

Trimestre	T1	T2	T3	T4
Signalements de messages suspects au référent	6	11	19	24
Clics lors de l'exercice simulé du trimestre (sur 80)	27	21	15	12
Incidents réels (compte piraté, poste infecté)	3	2	2	1

À vous de jouer – Questions

1. Calculez, pour chaque trimestre, les signalements pour 100 agents et le taux de clic. (4 pts)
2. Calculez l'évolution en pourcentage des signalements et des clics entre T1 et T4. (3 pts)
3. Le directeur dit : « Les signalements ont quadruplé, il y a donc quatre fois plus d'attaques ! » Répondez-lui. (3 pts)
4. Proposez une présentation de ce tableau de bord en une page pour le comité de direction (titre, trois chiffres clés, une phrase de conclusion, une décision demandée). (6 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Corrigés de la partie 6

Corrigé – Exercice 21.31

1. Légendes : 1 Constater ; 2 Fixer des objectifs ; 3 Animer ; 4 S'entraîner ; 5 Mesurer.
2. **B** est bien formulé : un comportement observable, un chiffre, un délai, une méthode de mesure. **A** n'est pas mesurable : « D'ici trois mois, 100 % des agents ont suivi une séance de 20 minutes et 80 % citent trois signes d'un message piégé au questionnaire. » **C** est irréaliste (« jamais ») : « Dans six mois, le taux de clic lors d'un exercice simulé est inférieur à 15 %. »
3. Exemples : « Dans trois mois, 100 % des postes se verrouillent automatiquement après 5 minutes et 90 % des sessions sont verrouillées lors d'un contrôle surprise. » ; « D'ici six mois, plus aucun compte partagé n'est utilisé dans le logiciel de soins. »
4. Sans **mesure de départ**, on ne peut pas savoir si la séance a eu un effet ; la mesure aide aussi à choisir les messages utiles (là où l'équipe se trompe le plus).

Corrigé – Exercice 21.32

1.

Service	Clic	Saisie	Signalement
Restauration (42)	14 / 42 = **33,3 %**	6 / 42 = **14,3 %**	5 / 42 = **11,9 %**
Diététique (8)	2 / 8 = **25,0 %**	0 / 8 = **0,0 %**	3 / 8 = **37,5 %**
Administration (30)	9 / 30 = **30,0 %**	4 / 30 = **13,3 %**	7 / 30 = **23,3 %**
Ensemble (80)	25 / 80 = **31,3 %**	10 / 80 = **12,5 %**	15 / 80 = **18,8 %**

2. La restauration a le taux de clic le plus élevé et le taux de signalement le plus bas. Le service diététique semble le plus prudent, mais il ne compte que **8 agents** : une personne de plus ou de moins change le taux de 12,5 points. On ne peut **pas conclure** ; il faut répéter la mesure.
3. **Information** préalable du personnel et de ses représentants (sans dire la date) ; accord de la direction et du DPO ; message qui n'exploite pas une peur excessive (faux licenciement, faux décès) ; **aucune sanction** ; résultats **anonymes** ; mots de passe saisis jamais enregistrés ; explication donnée tout de suite à la personne qui a cliqué (page pédagogique).
4. Sans nom ni classement des personnes ; en commençant par ce qui va bien (5 signalements) ; avec le vrai message et ses signes ; en expliquant que la cuisine est une cible (fournisseurs, livraisons) ; avec un objectif commun pour le prochain exercice.

Corrigé – Exercice 21.33

1. Exercice 1 : 25 / 80 = **31,25 %** ; exercice 2 : 12 / 80 = **15,0 %**. Conditions : n = 80 ≥ 30 ; exercice 1 : n × p = 25 et n × (1 – p) = 55 ; exercice 2 : 12 et 68 : toutes sont **supérieures ou égales à 5**.
2. Exercice 1 : 1,96 × √(0,3125 × 0,6875 / 80) ≈ 0,102 ; IC ≈ **[21,1 % ; 41,4 %]**. Exercice 2 : 1,96 × √(0,15 × 0,85 / 80) ≈ 0,078 ; IC ≈ **[7,2 % ; 22,8 %]**.
3. Les intervalles se **chevauchent** (entre 21,1 % et 22,8 %). La baisse est importante (de 31,3 % à 15,0 %, soit 16,3 points) et va dans le bon sens, mais avec 80 agents on ne peut pas affirmer avec certitude qu'elle n'est pas due au hasard. Il faut **poursuivre** la mesure sur plusieurs exercices.
4. Le second message était peut-être **plus facile** à repérer ; les agents ont **parlé** du premier exercice entre eux ; une partie de l'équipe a **changé** (départs, remplacements) ; certains se méfient de tous les messages pendant quelques semaines puis oublient ; l'exercice n'a pas eu lieu au même moment de l'année.

Corrigé – Exercice 21.34

1. Somme avant : 62 ; moyenne : 62 / 12 = **5,17 sur 10**. Somme après : 88 ; moyenne : 88 / 12 = **7,33 sur 10**. Gain moyen : 26 / 12 = **2,17 points**.
2. Avant : 2 agents (A5 et A9), soit 2 / 12 = **16,7 %**. Après : 9 agents (A1, A2, A3, A5, A6, A7, A9, A10, A11), soit 9 / 12 = **75,0 %**.
3. **A9** ne gagne qu'un point, mais il avait déjà 8 sur 10 (il passe à 9) : ce n'est pas un problème. L'agent qui reste le plus bas est **A12** (de 3 à 5). On ne le désigne pas : on propose à **toute l'équipe** un rappel court et une fiche illustrée, et on reste disponible pour répondre aux questions en individuel ; peut-être A12 a-t-il des difficultés de lecture du questionnaire.
4. Non : le questionnaire mesure des **connaissances** juste après la séance, pas ce que les agents feront face à un vrai message. Indicateurs de comportement : nombre de **signalements** au référent ; taux de clic lors d'un exercice simulé ; part des sessions verrouillées lors d'un passage surprise ; disparition des mots de passe affichés.

Corrigé – Exercice 21.35

1. Exemple : (1) « **Un fournisseur ne change jamais de RIB ou de commande par un simple courriel** : j'appelle le numéro habituel » (la cuisine reçoit beaucoup de messages de fournisseurs) ; (2) « **Je ne branche aucune clé USB inconnue** sur les postes de la cuisine » (postes partagés) ; (3) « **La liste des régimes ne sort pas de la cuisine** : pas de photo sur le groupe de messagerie » (données de santé sur des téléphones personnels).
2. Déroulé (debout, près des postes) : **2 min** : un vrai exemple projeté ou imprimé en grand (faux courriel de fournisseur) ; **5 min** : « Trouvez les 5 erreurs » par petits groupes ; **4 min** : les trois messages clés et le geste à faire (qui appeler) ; **2 min** : une question à chacun (« que faites-vous si… ? ») ; **2 min** : remise d'une affiche plastifiée (lavable) avec trois pictogrammes et le numéro du référent. Support : affiche A3 plastifiée, gros caractères, pictogrammes, fixée près des postes.
3. Répéter la séance pour **chaque équipe** (matin, après-midi, week-end), à l'heure de prise de poste ; utiliser des **pictogrammes**, des exemples visuels et des démonstrations ; s'appuyer sur un agent relais dans chaque équipe ; traduire l'affiche si besoin.
4. La liste des régimes est une **donnée de santé** : elle ne doit pas circuler sur des téléphones personnels ni dans une messagerie grand public. Proposer : la liste reste **affichée en cuisine** ou consultable sur le poste ; un outil de messagerie professionnel, si un échange est nécessaire ; suppression des photos déjà envoyées ; règle écrite dans le règlement de la cuisine.

Corrigé – Exercice 21.36

1.

Trimestre	T1	T2	T3	T4
Signalements pour 100 agents	6 / 80 × 100 = **7,5**	**13,8**	**23,8**	**30,0**
Taux de clic	27 / 80 = **33,8 %**	**26,3 %**	**18,8 %**	**15,0 %**

2. Signalements : (24 – 6) / 6 × 100 = **+ 300 %** (multipliés par 4). Clics : (12 – 27) / 27 × 100 = **– 55,6 %**.
3. Non : les signalements mesurent la **vigilance** des agents, pas le nombre d'attaques. Les agents repèrent et signalent maintenant des messages qu'ils ignoraient ou ouvraient avant. Les incidents réels ont d'ailleurs **diminué** (de 3 à 1 par trimestre). C'est un signe de réussite du plan.
4. Exemple : **Titre** : « Sensibilisation à la cybersécurité : une équipe plus vigilante en un an ». **Chiffres clés** : signalements multipliés par 4 (de 6 à 24 par trimestre) ; taux de clic divisé par plus de 2 (de 33,8 % à 15,0 %) ; incidents réels de 3 à 1 par trimestre (8 sur l'année). **Conclusion** : « Les gestes progressent, mais un agent sur sept clique encore : l'effort doit être maintenu. » **Décision demandée** : « Reconduire les quarts

> d'heure sécurité et activer la double authentification pour tous les comptes avant la fin du prochain trimestre. »

Partie 7 – Hors les murs, objets connectés, petites structures et analyse de risque

Objectifs – Objectifs de la partie

- Appliquer les règles de sécurité en télétravail et en déplacement.
- Analyser les risques d'un objet connecté utilisé dans un programme de santé.
- Coter des risques (vraisemblance et gravité) et mesurer l'effet des mesures.
- Chiffrer la sécurité d'une petite structure.
- Sécuriser le Wi-Fi d'un lieu qui reçoit du public.
- Organiser la fin de vie du matériel informatique.

À connaître par cœur pour le bts – À connaître par cœur

- Hors de la structure : **matériel professionnel**, connexion de confiance et accès sécurisé, **chiffrement** du disque et des clés USB, **discrétion** (écran, appels), **verrouillage**, jamais de matériel laissé seul.
- Un **objet connecté** (balance, podomètre, lecteur de glycémie) collecte souvent plus que nécessaire : on applique la **minimisation**, on change le mot de passe par défaut, on fait les mises à jour, on vérifie où vont les données.
- **Cotation** d'un risque : vraisemblance (de 1 à 4) × gravité (de 1 à 4). Une mesure peut réduire la vraisemblance (rendre l'événement moins probable) ou la gravité (en limiter les conséquences).
- Une **petite structure** n'a pas de service informatique : elle s'appuie sur des outils simples, des prestataires engagés par contrat et *cybermalveillance.gouv.fr*.
- Un matériel qui quitte la structure (don, revente, recyclage) est **effacé de façon sûre** ou son disque est détruit.

Exercice 21.37 – Travailler hors de la structure (12 points)

★★☆☆☆ *Niveau 2 – application · durée conseillée : 10 min*

Mise en situation – Mise en situation

La diététicienne d'un réseau de santé (fictif) travaille deux jours par semaine chez elle et se déplace dans les maisons de santé du territoire.

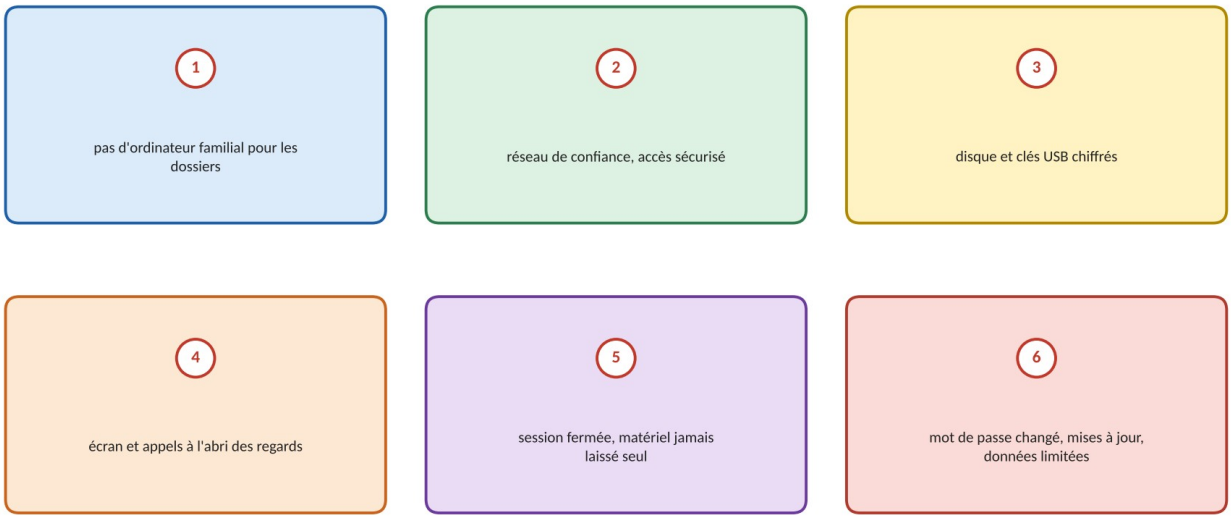


Figure 21.11 – Document 1 – Travailler hors de la structure en sécurité (schéma à légender)

Document 2 – Ce qu'elle fait

- **A.** Elle rédige ses comptes rendus sur l'ordinateur familial, que ses enfants utilisent aussi.
- **B.** Dans le train, elle relit un bilan nutritionnel sur son portable ; son voisin voit l'écran.
- **C.** Elle se connecte au logiciel du réseau par le Wi-Fi gratuit d'un café, sans protection.
- **D.** Elle laisse son portable dans la voiture pendant une visite à domicile.
- **E.** Elle téléphone à un médecin au sujet d'un patient, dans la salle d'attente d'une gare.
- **F.** Elle copie des dossiers sur une clé USB non chiffrée pour travailler chez elle.

À vous de jouer – Questions

1. Légendez les éléments numérotés 1 à 6 du document 1. (3 pts)
2. Pour chaque pratique du document 2, nommez la règle non respectée et la bonne pratique. (6 pts)
3. Que doit prévoir le réseau pour que la diététicienne puisse bien travailler à distance ? (3 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.38 – La balance connectée (14 points)

★★★☆☆ *Niveau 3 – analyse · durée conseillée : 20 min*

Mise en situation – Mise en situation

Un programme de suivi de patients en surpoids après une chirurgie de l'obésité (fictif) envisage de prêter à **40 patients** une balance connectée et un bracelet, fournis par une jeune entreprise.

Document 1 – La fiche du produit (fictive)

- La balance envoie le poids et la composition corporelle à chaque pesée (on prévoit **une pesée par jour**).
- Le bracelet enregistre les pas, le sommeil et la **position GPS toutes les 5 minutes**.
- Les données sont envoyées sur les serveurs de l'entreprise, « dans le monde entier » ; l'application est gratuite et « financée par des partenaires ».
- Mot de passe par défaut de la balance : « 0000 », identique pour tous les appareils.

À vous de jouer – Questions

1. Calculez le nombre de pesées et le nombre de positions GPS enregistrées en un an pour les 40 patients. Commentez au regard de la minimisation. (4 pts)

2. Relevez quatre risques pour les patients dans le document 1. (4 pts)

3. Listez les questions à poser à l'entreprise et les conditions à exiger avant de choisir ce produit. (4 pts)

4. Quelle alternative plus simple proposez-vous pour le suivi du poids ? (2 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.39 – Coter les risques (16 points)

★★★☆☆ *Niveau 3 – analyse · durée conseillée : 25 min*

Mise en situation – Mise en situation

Le service diététique d'un hôpital de jour (fictif) réalise une analyse de risques simplifiée avec le responsable de la sécurité. Chaque scénario est coté en **vraisemblance** (V, de 1 à 4) et en **gravité** (G, de 1 à 4) ; le niveau de risque est V × G. Repères : 1 à 3 faible ; 4 à 7 modéré ; 8 à 11 élevé ; 12 à 16 critique.

Document 1 – Les scénarios (cotations fictives)

Scénario	V	G	Mesure envisagée
A. Hameçonnage et piratage d'une messagerie	3	4	Double authentification
B. Panne du logiciel de restauration pendant une journée	2	3	Liste papier des régimes et contrat de rétablissement
C. Compte rendu envoyé au mauvais destinataire	4	2	Messagerie sécurisée de santé et vérification du destinataire
D. Rançongiciel sur le serveur	2	4	Sauvegarde déconnectée et testée
E. Vol d'un ordinateur portable non chiffré	3	3	Chiffrement du disque
F. Incendie du local du serveur	1	4	Sauvegarde hors site

Cotations après mesures proposées par le responsable : A (V 1, G 4) ; B (V 1, G 3) ; C (V 2, G 2) ; D (V 1, G 3) ; E (V 3, G 1) ; F (V 1, G 2).

À vous de jouer – Questions

1. Calculez le niveau de chaque risque avant mesures et classez les scénarios du plus grave au moins grave. (4 pts)
2. Calculez le niveau après mesures. Pour chaque mesure, dites si elle agit sur la vraisemblance ou sur la gravité. (5 pts)
3. Calculez la somme des niveaux avant et après, et la baisse en pourcentage. (3 pts)
4. Quelles sont les limites de cette méthode ? Quelle méthode plus complète existe pour les grandes structures ? (4 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.40 – La sécurité d'une diététicienne libérale (14 points)

★★★☆☆ *Niveau 3 – analyse · durée conseillée : 20 min*

Mise en situation – Mise en situation

Une diététicienne libérale (fictive) réalise **900 consultations par an** pour un chiffre d'affaires de **52 000 €**. Elle se demande si « la cybersécurité, c'est pour les hôpitaux ».

Document 1 – Les mesures et leurs coûts (offres fictives, 2028)

- Gestionnaire de mots de passe : 3 € par mois.
- Sauvegarde externalisée chiffrée : 8 € par mois.
- Deux disques externes chiffrés pour la règle 3-2-1 : 70 € chacun, à renouveler tous les 3 ans.
- Logiciel de suivi des patients hébergé chez un hébergeur certifié HDS : 30 € par mois.
- Double authentification, mises à jour, verrouillage automatique, chiffrement du portable : sans coût.

À vous de jouer – Questions

1. Calculez le coût annuel des mesures (les disques sont répartis sur 3 ans), le coût par consultation et la part du chiffre d'affaires. (5 pts)
2. Répondez à sa question en trois arguments, dont un sur ses obligations. (4 pts)
3. Proposez-lui un plan en trois étapes : cette semaine, ce mois-ci, cette année. (3 pts)
4. Vers qui peut-elle se tourner si elle est victime d'une attaque ? (2 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.41 – Le Wi-Fi de la salle d'attente (14 points)

★★★☆☆ *Niveau 3 – analyse · durée conseillée : 20 min*

Mise en situation – Mise en situation

Une maison de santé (fictive) veut offrir le Wi-Fi aux patients dans la salle d'attente et afficher un code QR « pour donner votre avis ». Aujourd'hui, un seul réseau Wi-Fi relie les ordinateurs des professionnels, l'imprimante et la box ; son mot de passe est affiché à l'accueil pour les patients.

À vous de jouer – Questions

1. Expliquez pourquoi la situation actuelle est dangereuse. (3 pts)
2. Proposez une organisation des réseaux et des règles pour le Wi-Fi des patients. (4 pts)
3. Quels risques présente un code QR affiché dans un lieu public ? Comment les limiter ? (4 pts)
4. Rédigez l'affichette destinée aux patients (5 lignes au plus). (3 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.42 – Les vieux ordinateurs (14 points)

★★★☆☆ *Niveau 3 – analyse · durée conseillée : 20 min*

Mise en situation – Mise en situation

Un service de restauration hospitalière (fictif) remplace **6 ordinateurs**. Le cadre propose de les donner à une association de quartier qui aide des familles à faire leurs démarches en ligne. Sur ces postes ont été traités : les listes de régimes des patients, les fiches de production, la messagerie des agents et la comptabilité des fournisseurs.

À vous de jouer – Questions

1. Quelles données peuvent rester sur les disques ? Pourquoi la mise à la corbeille ou le formatage rapide ne suffisent-ils pas ? (4 pts)
2. Décrivez la procédure à suivre avant le don (au moins quatre étapes). (5 pts)
3. Un des postes ne démarre plus. Que faire de son disque ? (2 pts)
4. Le don est-il une bonne idée ? Donnez un argument pour et une condition. (3 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Corrigés de la partie 7

Corrigé – Exercice 21.37

1. Légendes : 1 Matériel professionnel ; 2 Connexion protégée ; 3 Chiffrement ; 4 Discrétion ; 5 Verrouillage ; 6 Objets connectés.
2. A : **matériel professionnel** : travailler sur un ordinateur fourni par le réseau, réservé au travail. B : **discrétion** : filtre de confidentialité, relire plus tard ou se placer contre une paroi. C : **connexion protégée** : partage de connexion de son téléphone ou accès sécurisé fourni par le réseau ; pas de Wi-Fi public sans protection. D : **verrouillage** et surveillance : ne jamais laisser le matériel seul, l'emporter ou le ranger hors de vue dans un endroit fermé. E : **discrétion** : s'éloigner, ne pas citer le nom du patient, rappeler plus tard. F : **chiffrement** : clé chiffrée, ou mieux, accès à distance aux dossiers sans copie.
3. Un ordinateur professionnel chiffré, avec mises à jour gérées ; un **accès sécurisé** au logiciel (double authentification) ; une **charte** du travail à distance ; un filtre de confidentialité ; un numéro d'assistance ; la règle de ne pas copier de dossier sur un support personnel.

Corrigé – Exercice 21.38

1. Pesées : 40 × 365 = **14 600 par an**. Positions GPS : 12 par heure × 24 = 288 par jour ; 288 × 40 × 365 = **4 204 800 par an**. Le suivi du poids n'a pas besoin de la **localisation** des patients : ces millions de positions révèlent le domicile, le travail, les habitudes ; elles ne sont pas nécessaires et contredisent la **minimisation**.
2. Données de santé (poids, composition corporelle, sommeil) hébergées « dans le monde entier », sans garantie **HDS** ni encadrement des transferts ; financement par des « partenaires » qui fait craindre une **réutilisation** commerciale des données ; mot de passe par défaut **identique** pour tous (n'importe qui peut se connecter à la balance) ; suivi de la position, qui peut exposer la vie privée et la sécurité ; poids quotidien qui peut favoriser une obsession de la balance chez des patients fragiles.
3. Où les données sont-elles hébergées, chez un hébergeur certifié HDS ? Qui y a accès, et sont-elles transmises ou vendues à des partenaires ? Peut-on **désactiver** le GPS et les données inutiles ? Le mot de passe est-il **unique et modifiable** ? Les mises à jour de sécurité sont-elles prévues, et pendant combien de temps ? Comment les données sont-elles **supprimées** à la fin du programme ? Conditions : contrat de sous-traitance, analyse d'impact avec le DPO, information claire des patients, participation **facultative**.
4. Une pesée **hebdomadaire** sur une balance simple, notée par le patient dans un carnet ou dans l'outil sécurisé du programme, et vérifiée lors des consultations : moins de données, moins de risques, et un rapport à la balance plus serein.

Corrigé – Exercice 21.39

1. Niveaux : A 3 × 4 = **12** (critique) ; B 2 × 3 = **6** (modéré) ; C 4 × 2 = **8** (élevé) ; D 2 × 4 = **8** (élevé) ; E 3 × 3 = **9** (élevé) ; F 1 × 4 = **4** (modéré). Classement : **A** ; **E** ; **C et D** ; **B** ; **F**.
2. Après mesures : A 1 × 4 = **4** (la double authentification réduit la **vraisemblance**) ; B 1 × 3 = **3** (le contrat et la liste réduisent la **vraisemblance** d'une panne longue ; la liste aide aussi à limiter les erreurs) ; C 2 × 2 = **4** (la vérification réduit la **vraisemblance**, la messagerie sécurisée réduit la **gravité**, car le message ne part que vers des professionnels identifiés) ; D 1 × 3 = **3** (la sauvegarde réduit surtout la **gravité** ; ici le responsable a aussi réduit la vraisemblance d'une perte durable) ; E 3 × 1 = **3** (le chiffrement réduit la **gravité** : le vol reste possible mais les données sont illisibles) ; F 1 × 2 = **2** (la sauvegarde hors site réduit la **gravité**).
3. Avant : 12 + 6 + 8 + 8 + 9 + 4 = **47**. Après : 4 + 3 + 4 + 3 + 3 + 2 = **19**. Baisse : (47 – 19) / 47 × 100 = **59,6 %**.
4. Les cotations sont **subjectives** (elles dépendent de qui les fait) ; additionner des niveaux de risques différents n'a pas vraiment de sens (un risque critique ne se compense pas par plusieurs faibles) ; la méthode ne dit rien du coût des mesures ni de leur mise en œuvre réelle. Pour les structures plus grandes, l'ANSSI propose la méthode **EBIOS Risk Manager**, qui part des scénarios d'attaque et des

sources de risque.

Corrigé – Exercice 21.40

1. Gestionnaire : 3 × 12 = 36 € ; sauvegarde : 8 × 12 = 96 € ; disques : 2 × 70 / 3 = 46,67 € ; logiciel : 30 × 12 = 360 €. Total : **538,67 € par an**, soit 538,67 / 900 = **0,60 € par consultation** et 538,67 / 52 000 × 100 = **1,0 %** du chiffre d'affaires.
2. (1) Les petites structures sont **visées aussi** : les attaques sont souvent automatiques, elles touchent ceux qui sont mal protégés. (2) Elle a les mêmes **obligations** : sécurité adaptée au risque (article 32 du RGPD), hébergeur certifié HDS pour les données confiées à un prestataire, notification des violations, secret professionnel. (3) Une attaque peut lui faire **perdre** tous ses dossiers et des semaines de travail, et la confiance de ses patients, pour un coût de protection de 0,60 € par consultation.
3. **Cette semaine** : activer la double authentification et les mises à jour automatiques, verrouillage de session, chiffrement du portable. **Ce mois-ci** : gestionnaire de mots de passe (un mot de passe par service), règle 3-2-1 avec un disque débranché et une sauvegarde externalisée, test de restauration. **Cette année** : logiciel HDS, registre des traitements et procédure en cas d'incident, formation courte (fiches *cybermalveillance.gouv.fr*).
4. **cybermalveillance.gouv.fr** (diagnostic, prestataires de proximité), **17Cyber**, la police ou la gendarmerie (plainte), la **CNIL** (notification si données de patients touchées), son assureur, et l'association professionnelle des diététiciens.

Corrigé – Exercice 21.41

1. Les patients se connectent au **même réseau** que les ordinateurs des professionnels et l'imprimante : un appareil infecté ou une personne malveillante peut y chercher des failles, intercepter des échanges ou attaquer les postes qui contiennent des dossiers. Le mot de passe affiché est connu de tous et ne change jamais.
2. **Deux réseaux séparés** : un réseau professionnel (mot de passe connu des seuls professionnels, changé au départ d'une personne) et un **réseau invité** isolé, sans accès aux postes ni à l'imprimante. Règles : mot de passe invité changé régulièrement, débit limité, coupure la nuit, conditions d'usage affichées, box mise à jour et mot de passe d'administration changé.
3. Un code QR peut être **recouvert** par un faux code collé par-dessus, qui mène vers un faux site (vol de données ou de carte bancaire) ; le patient ne voit pas l'adresse avant de scanner. Limiter : code sous un cadre ou une vitre, vérifié chaque semaine ; adresse écrite en clair à côté ; questionnaire **anonyme** qui ne demande ni nom, ni données de santé, ni paiement ; version papier disponible.
4. Exemple : « Wi-Fi gratuit pour les patients : réseau "MSP-Invités", code à demander à l'accueil. Ce réseau est séparé de celui des professionnels. Évitez d'y faire des opérations bancaires. Notre questionnaire d'avis est anonyme et ne vous demande jamais de paiement ni de données personnelles. »

Corrigé – Exercice 21.42

1. Restes de listes de régimes (**données de santé**), fiches de production, messages des agents, identifiants enregistrés dans le navigateur, factures et coordonnées bancaires des fournisseurs. La corbeille et le formatage rapide **n'effacent pas** les données : ils suppriment seulement le « chemin » vers les fichiers, que des logiciels gratuits peuvent retrouver.
2. (1) **Sauvegarder** ce qui doit être conservé et vérifier que rien d'utile ne reste ; (2) **déconnecter** les comptes et retirer le poste des outils (messagerie, logiciel, licences) ; (3) **effacer de façon sûre** le disque avec un outil d'effacement reconnu, par le prestataire ; (4) réinstaller un système neuf ; (5) établir une **attestation** d'effacement par poste (numéro de série, date, méthode) ; (6) signer une convention de don avec l'association.
3. Si le poste ne démarre plus, on ne peut pas effacer le disque par logiciel : on **retire le disque** et on le fait

détruire (broyage ou destruction par un prestataire spécialisé, avec certificat). Le reste de l'ordinateur peut être donné ou recyclé sans disque.

4. **Pour** : le don prolonge la vie du matériel (moins de déchets électroniques) et aide des familles exclues du numérique. **Condition** : effacement sûr et attesté de chaque disque avant le départ ; les postes doivent encore recevoir des mises à jour de sécurité, sinon l'association hérite d'un matériel dangereux.

Partie 8 – Synthèse et cas complet

Objectifs – Objectifs de la partie

- Intégrer la cybersécurité dans un projet d'intervention en santé publique.
- Relire et corriger une charte informatique.
- Répondre aux questions du jury sur le volet numérique d'un projet.
- Rédiger une note de synthèse pour obtenir une décision.
- Choisir des mesures sous contrainte de budget.
- Traiter un cas complet sur 40 points.

À connaître par cœur pour le bts – À connaître par cœur

- Dans un projet, la cybersécurité se prévoit **dès la conception** : quelles données, quels outils, qui y a accès, quel hébergement, que faire en cas d'incident.
- Une recommandation convaincante est **chiffrée** (coût, effet attendu), **priorisée** et accompagnée d'**indicateurs** de suivi.
- Le **responsable du traitement** (la structure) reste responsable de la sécurité, même quand il confie les données à un prestataire (sous-traitant, article 28 du RGPD).
- Devant le jury : partir du **besoin** des personnes, citer les textes avec leur date, distinguer ce qui est **réel** de ce qui est **fictif**, et reconnaître les limites de son travail.

Exercice 21.43 – La check-list cybersécurité d'un projet (12 points)

★★★☆☆ *Niveau 3 – analyse · durée conseillée : 20 min*

Mise en situation – Mise en situation

Pendant votre stage dans une plateforme d'accompagnement et de répit des aidants (fictive), vous concevez un cycle de 6 ateliers « Bien nourrir son proche » en visioconférence, avec inscription en ligne, envoi de recettes et un questionnaire d'évaluation.

À vous de jouer – Questions

1. Construisez une check-list d'au moins huit questions de cybersécurité à se poser pour ce projet, classées par étape (inscription, ateliers, envoi de documents, évaluation, fin du projet). (6 pts)
2. Pour trois de ces questions, donnez la réponse que vous retenez pour le projet. (3 pts)
3. Comment aider les aidants peu à l'aise avec le numérique sans les mettre en danger ? (3 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.44 – Relire la charte informatique (14 points)

★★★☆☆ *Niveau 3 – analyse · durée conseillée : 20 min*

Mise en situation – Mise en situation

Une association gestionnaire de foyers d'hébergement (fictive) a rédigé une charte informatique pour ses salariés et ses stagiaires. On vous demande de la relire.

Document 1 – Extraits de la charte

1. « Pour gagner du temps, chaque service dispose d'un compte commun et d'un mot de passe partagé. »
2. « Le mot de passe doit comporter 6 caractères et être changé tous les mois. »
3. « Les clés USB personnelles sont autorisées pour transporter les dossiers des résidents. »
4. « En cas de message suspect, supprimez-le sans en parler, pour ne pas déranger le service informatique. »
5. « Les mises à jour peuvent être reportées si elles gênent le travail. »
6. « Les stagiaires utilisent le compte de leur tuteur. »
7. « Toute personne qui clique sur un lien piégé fera l'objet d'une sanction. »
8. « Les salariés peuvent consulter les dossiers de tous les résidents de l'association. »

À vous de jouer – Questions

1. Pour chaque article, expliquez le problème et proposez une nouvelle rédaction. (12 pts)
2. Quel article supplémentaire proposez-vous ? (2 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.45 – Les questions du jury (12 points)

★★★★☆ *Niveau 4 – situation professionnelle · durée conseillée : 25 min*

Mise en situation – Mise en situation

Au temps 1 de l'épreuve E5, vous présentez un projet de repérage de la dénutrition dans une résidence autonomie (fictive), avec un fichier de suivi des résidents. Le jury vous pose des questions sur le volet numérique.

Document 1 – Les questions du jury

1. « Où était rangé votre fichier de suivi, et qui pouvait l'ouvrir ? »
2. « Si l'ordinateur de la résidence avait été volé, qu'auriez-vous fait ? »
3. « Vous avez envoyé vos résultats à votre tutrice par courriel ? Comment ? »
4. « La cybersécurité, ce n'est pas le métier d'un diététicien, non ? »

À vous de jouer – Questions

1. Rédigez une réponse orale de 60 mots au plus pour chaque question. (10 pts)
2. Quelles erreurs faut-il éviter dans ces réponses ? (2 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.46 – La note à la direction (14 points)

★★★★☆ *Niveau 4 – situation professionnelle · durée conseillée : 30 min*

Mise en situation – Mise en situation

Dans un centre de soins de suite et de réadaptation nutritionnelle (fictif), trois incidents ont eu lieu en un an : une messagerie piratée, une clé USB perdue avec des bilans, une panne du logiciel de restauration de deux jours. Votre tutrice vous demande une note d'une page pour obtenir de la direction trois décisions.

À vous de jouer – Questions

1. Choisissez les trois décisions à demander et justifiez votre choix. (3 pts)
2. Rédigez la note : objet, constat (avec les trois incidents), propositions chiffrées (coûts fictifs à justifier), bénéfices pour les patients, indicateurs, décisions demandées. (9 pts)
3. Quelle est la règle d'or pour qu'une telle note soit lue et suivie ? (2 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.47 – Choisir avec 2 500 € (16 points)

★★★★☆ *Niveau 4 – situation professionnelle · durée conseillée : 30 min*

Mise en situation – Mise en situation

Une association de prévention en nutrition (fictive), 12 salariés, dispose de **2 500 €** pour la sécurité informatique cette année. Avec le prestataire, elle a estimé pour chaque mesure une « réduction de risque » en points (somme des baisses de niveau de risque, méthode de l'exercice 21.39).

Document 1 – Les mesures possibles (données fictives)

Mesure	Coût la première année	Réduction de risque (points)
M1. Double authentification pour tous les comptes	0 €	8
M2. Sauvegarde externalisée avec copie déconnectée	900 €	10
M3. Formation de 2 heures pour toute l'équipe	1 200 €	7
M4. Remplacement de deux postes obsolètes	1 380 €	6
M5. Gestionnaire de mots de passe	650 €	5
M6. Chiffrement des ordinateurs portables	0 €	4
M7. Exercice de crise d'une demi-journée	400 €	3

À vous de jouer – Questions

1. Calculez le coût total de toutes les mesures et la réduction totale de risque. (2 pts)
2. Calculez, pour chaque mesure payante, le coût d'un point de réduction de risque. (3 pts)
3. Proposez la combinaison de mesures qui donne la plus grande réduction de risque sans dépasser 2 500 €. Justifiez par des calculs, en comparant au moins deux combinaisons. (6 pts)
4. Calculez la part de la réduction totale obtenue et la part du coût total dépensée. (2 pts)
5. Quelle mesure non retenue doit être programmée l'an prochain, et pourquoi ? (3 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Exercice 21.48 – Cas complet : « Cure connectée » (40 points)

★★★★★ *Niveau 5 – cas complet au format de l'épreuve · durée conseillée : 2 h*

Mise en situation – Mise en situation

Vous effectuez votre stage aux **Thermes de Vals-les-Sources** (établissement fictif), qui accueillent chaque année environ **4 800 curistes** pour des cures de 18 jours, dont beaucoup présentent un surpoids, une obésité ou un diabète de type 2. Les thermes proposent des ateliers d'éducation nutritionnelle animés par Mme Aubert, diététicienne, votre tutrice. Une jeune entreprise propose de « connecter » la cure. Un pilote a été mené au printemps 2028 avec **600 curistes**. La directrice vous demande d'analyser le projet et l'incident du pilote, et de préparer sa décision.

Document 1 – Le projet « ThermoForme » (proposition commerciale, janvier 2028, fictive)

1. **Inscription** dans l'application avec le numéro de sécurité sociale, l'ordonnance de cure scannée (avec le diagnostic) et une photo d'identité.
2. **Photo de chaque repas**, analysée par un outil d'intelligence artificielle qui affiche une estimation des calories.
3. **Balance connectée** dans chaque chambre ; le poids est envoyé automatiquement.
4. **Classement** affiché sur les écrans du hall : « Les 10 curistes qui ont perdu le plus de poids cette semaine », avec prénom et initiale du nom.
5. Les données sont stockées par l'entreprise « chez un grand fournisseur de cloud » ; tablettes prêtées dans les chambres, connectées au Wi-Fi unique des thermes (le même que celui des bureaux).

Document 2 – L'incident du pilote (relevé de la directrice, données fictives)

- Sur les 600 curistes du pilote, **552** avaient donné une adresse électronique.
- **Lundi 15 mai, 9 h** : un chercheur en sécurité informe l'entreprise que sa base de données est **accessible sur Internet sans mot de passe** depuis trois jours (600 dossiers : identité, numéro de sécurité sociale, ordonnance, poids quotidiens).
- **Mercredi 17 mai, 15 h** : l'entreprise prévient les thermes.
- **Jeudi 18 mai** : les 552 curistes reçoivent un faux courriel « ThermoForme – téléchargez votre bilan de cure » avec un lien vers une fausse page de connexion. **138** cliquent, **41** saisissent leur identifiant et leur mot de passe.

Document 3 – Les coûts sur 3 ans (offres fictives, 2028)

- **Option A** : ThermoForme pour tous les curistes : **18 € par curiste**.
- **Option B** : plateforme d'éducation nutritionnelle hébergée chez un hébergeur certifié HDS, sans balance ni classement, avec ateliers renforcés : **42 000 €** de mise en place, puis **4 € par curiste**.
- Hypothèse : 4 800 curistes par an pendant 3 ans.

Document 4 – Repères et textes (données réelles, à citer avec leur date)

- Règlement (UE) 2016/679 (RGPD) : article 9 (données de santé) ; article 28 (sous-traitant) ; article 32 (sécurité) ; articles 33 et 34 (notification à la CNIL dans les 72 heures, information des personnes en cas de risque élevé).
- Code de la santé publique, article L1111-8 : hébergement des données de santé chez un hébergeur certifié.
- ANSSI, *Guide d'hygiène informatique* (2017) ; *cybermalveillance.gouv.fr* (depuis 2017) ; 17Cyber (depuis le 17 décembre 2024).

- Haute Autorité de santé, *Guide du parcours de soins : surpoids et obésité chez l'adulte* (2023) : l'objectif n'est pas seulement la perte de poids, mais aussi la qualité de vie et la prévention de la reprise.

À vous de jouer – Travail à faire

Partie A – Analyser le projet (14 points)

1. Listez les données traitées par ThermoForme, dites lesquelles sont des données de santé et lesquelles sont inutiles au but éducatif. (4 pts)

2. Analysez les éléments 1, 2, 3 et 5 du document 1 : risque pour les curistes et mesure qui le corrige. (4 pts)

3. Analysez le classement du hall sur les plans de la confidentialité, de l'éthique et de l'éducation nutritionnelle. (3 pts)

4. Proposez l'organisation du Wi-Fi et des tablettes prêtées. (3 pts)

Partie B – L'incident et les chiffres (14 points)

5. Calculez le taux de clic et le taux de saisie parmi les 552 curistes, et la part des curistes ayant cliqué qui ont saisi leurs identifiants. Calculez l'intervalle de confiance à 95 % du taux de clic, en vérifiant les conditions. Commentez. (5 pts)

6. Pour la base exposée : qui est responsable du traitement, qui est sous-traitant, qui notifie la CNIL et avant quelle heure ? Les curistes doivent-ils être informés ? Que pensez-vous du délai mis par l'entreprise pour prévenir les thermes ? (5 pts)

7. Calculez le coût des options A et B sur 3 ans et le coût par curiste. (3 pts)

8. Expliquez le lien probable entre l'exposition de la base et le faux courriel du jeudi. (1 pt)

Partie C – Décider et communiquer (12 points)

9. Proposez votre recommandation à la directrice : option retenue, quatre mesures prioritaires et trois indicateurs de suivi. (4 pts)

10. Rédigez le message d'information aux 600 curistes du pilote (10 lignes au plus). (3 pts)

11. Proposez une séance de 20 minutes « Mes données de santé en ligne » intégrée aux ateliers de la cure. (3 pts)

12. La directrice vous dit : « C'est l'entreprise qui a fait l'erreur, nous n'y sommes pour rien. » Rédigez votre réponse orale (80 mots au plus). (2 pts)

Ma réponse

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

Ma réponse (suite)

Barème – Barème du cas complet

Partie A : 14 points (questions 1 à 4). Partie B : 14 points (questions 5 à 8). Partie C : 12 points (questions 9 à 12). Total : 40 points. Un calcul juste sans unité ni phrase de conclusion vaut la moitié des points.

Corrigés de la partie 8

Corrigé – Exercice 21.43

1. Exemple de check-list :

Étape	Questions
Inscription	Quelles données sont **vraiment nécessaires** (nom, contact, besoins alimentaires du proche) ? Où le formulaire est-il hébergé ? Les personnes sont-elles informées de l'usage des données ?
Ateliers	L'outil de visioconférence est-il fiable et protégé (lien par session, salle d'attente) ? Enregistre-t-on les séances (non, sauf accord et besoin réel) ? Comment éviter qu'une personne extérieure rejoigne la séance ?
Envoi de documents	Les recettes sont-elles envoyées sans liste des participants visible (copie cachée) ? Aucune donnée de santé dans les envois ?
Évaluation	Le questionnaire est-il **anonyme** et sans donnée de santé inutile ?
Fin du projet	Quand et comment supprime-t-on la liste des inscrits ? Qui le vérifie ?
Incident	Qui prévenir en cas d'erreur d'envoi ou de lien diffusé ?

2. Exemples : inscription : nom, prénom, téléphone ou courriel, et « restrictions alimentaires du proche » en texte libre facultatif, sans diagnostic ; ateliers : lien unique par séance envoyé la veille, salle d'attente activée, pas d'enregistrement ; fin : liste supprimée un mois après le dernier atelier, bilan anonyme conservé.

3. Proposer un **appel test** la veille ; un tutoriel en gros caractères ; un numéro de téléphone pour être aidé ; la possibilité de suivre l'atelier par téléphone ; ne jamais demander de mot de passe par téléphone ; rappeler que la plateforme n'enverra jamais de lien de paiement.

Corrigé – Exercice 21.44

1.

Article	Problème	Nouvelle rédaction
1	Compte partagé : pas de traçabilité, impossible de retirer l'accès à une personne	« Chaque personne a un compte nominatif ; aucun compte n'est partagé. »
2	6 caractères : trop court ; changement mensuel : pousse à des mots de passe prévisibles	« Le mot de passe compte au moins 12 caractères variés ou une phrase de passe ; il est changé en cas de doute ou de fuite. La double authentification est activée. »
3	Clés personnelles non chiffrées : perte et virus	« Les dossiers ne sont copiés que sur des supports fournis par l'association et chiffrés, et seulement si c'est nécessaire. »
4	Le service ne sait pas que d'autres reçoivent le même message	« Tout message suspect est signalé au référent, puis supprimé. Signaler ne dérange jamais. »
5	Mises à jour reportées : failles ouvertes	« Les mises à jour de sécurité sont installées dans les 7 jours ; le redémarrage est prévu en fin de journée. »
6	Pas de traçabilité, le tuteur répond de tout	« Les stagiaires ont un compte personnel, aux droits limités, désactivé à la fin du stage. »
7	La peur de la sanction empêche de signaler	« Toute personne qui pense avoir cliqué sur un lien piégé prévient tout de suite le référent ; elle ne sera pas sanctionnée. »

Article	Problème	Nouvelle rédaction
8	Accès sans besoin : atteinte au secret et à la confidentialité	« Chaque salarié accède aux dossiers des seuls résidents qu'il accompagne ; les accès sont tracés. »

2. Exemple : « En cas d'incident (message de rançon, vol de matériel, envoi par erreur), je débranche le poste du réseau sans l'éteindre, je préviens immédiatement le référent au [numéro] et je note l'heure et les faits. »

Corrigé – Exercice 21.45

1. **Question 1** : « Le fichier était rangé sur le serveur de la résidence, dans un dossier accessible à la seule infirmière coordinatrice, à ma tutrice et à moi, avec un compte personnel. Je n'en ai fait aucune copie sur une clé ou sur mon ordinateur. Il a été supprimé à la fin du stage, sauf les données utiles au suivi des résidents. » **Question 2** : « J'aurais prévenu tout de suite ma tutrice et la direction, noté l'heure et les faits, et fait porter plainte. La direction, responsable du traitement, aurait évalué le risque avec son DPO et notifié la CNIL dans les 72 heures, puis informé les résidents si le risque était élevé, par exemple si le disque n'était pas chiffré. » **Question 3** : « Je n'ai envoyé que des résultats agrégés, sans nom, en pièce jointe protégée. Les données nominatives sont restées sur le serveur. Si j'avais dû envoyer des données de santé, j'aurais utilisé la messagerie sécurisée de santé de la résidence. » **Question 4** : « Le diététicien n'est pas informaticien, mais il traite des données de santé et doit les protéger : c'est le secret professionnel. Un mauvais régime dû à une donnée modifiée ou un repas non servi à cause d'une panne touchent directement les patients. Et une bonne hygiène informatique, ce sont surtout des gestes simples. »
2. Répondre de façon vague (« c'était sécurisé ») ; inventer une règle ou un délai ; rejeter la responsabilité sur l'informatique ; oublier les conséquences pour les personnes ; dire qu'on a utilisé une messagerie personnelle ou une clé non chiffrée sans le reconnaître comme une erreur.

Corrigé – Exercice 21.46

1. Exemple : (1) **double authentification** pour toutes les messageries (répond à l'incident 1, sans coût) ; (2) **interdiction des clés USB non chiffrées** et fourniture de clés chiffrées (incident 2) ; (3) **mode dégradé** de la restauration : export quotidien des régimes et exercice annuel (incident 3). Les trois répondent aux incidents réellement vécus, sont peu coûteuses et protègent directement les patients.
2. Exemple de note :

Objet : trois décisions pour sécuriser les données et les repas des patients. **Constat** : en un an, trois incidents : piratage d'une messagerie (messages piégés envoyés aux partenaires), perte d'une clé USB contenant des bilans nutritionnels, deux jours sans logiciel de restauration (régimes gérés sur une liste ancienne). **Propositions** : (1) double authentification sur toutes les messageries : sans coût, mise en place en un mois ; (2) cinq clés USB chiffrées pour les déplacements : 5 × 40 € = 200 € (coût fictif), et interdiction des clés personnelles ; (3) export automatique quotidien des régimes et textures, classeur de mode dégradé, exercice annuel : 600 € par an (coût fictif, contrat du prestataire). Total : 800 € la première année. **Bénéfices pour les patients** : confidentialité de leurs bilans, repas adaptés même en cas de panne. **Indicateurs** : part des comptes avec double authentification (cible 100 % dans 3 mois) ; nombre de clés non chiffrées en circulation (cible 0) ; délai pour produire la liste papier lors de l'exercice (cible moins de 30 minutes). **Décisions demandées** : valider les trois mesures et le budget de 800 €.

3. **Une page**, un **constat** concret, des **décisions précises** et chiffrées : la direction doit pouvoir décider en lisant la note en deux minutes.

Corrigé – Exercice 21.47

1. Coût total : 0 + 900 + 1 200 + 1 380 + 650 + 0 + 400 = **4 530 €**. Réduction totale : 8 + 10 + 7 + 6 + 5 + 4 + 3 = **43 points**.

2. M2 : 900 / 10 = **90 € par point** ; M3 : 1 200 / 7 ≈ **171 €** ; M4 : 1 380 / 6 = **230 €** ; M5 : 650 / 5 = **130 €** ; M7 : 400 / 3 ≈ **133 €**. M1 et M6 ne coûtent rien.

3. On retient d'abord **M1 et M6** (gratuites) : 12 points. Avec 2 500 € : **M2 + M5 + M7** (choix « au meilleur rapport ») : 1 950 €, 18 points, soit 30 points au total ; il reste 550 €, qui ne suffisent pour aucune autre mesure. **M2 + M3 + M7** : 900 + 1 200 + 400 = **2 500 €**, 10 + 7 + 3 = 20 points, soit **32 points** au total. **M2 + M4** : 2 280 €, 16 points, soit 28 points. La meilleure combinaison est **M1, M2, M3, M6 et M7** : **32 points pour 2 500 €**. Le classement par coût par point ne donne pas toujours la meilleure solution : il faut aussi utiliser tout le budget.

4. Réduction obtenue : 32 / 43 × 100 = **74,4 %** ; coût dépensé : 2 500 / 4 530 × 100 = **55,2 %**.

5. Le **gestionnaire de mots de passe** (M5) : il complète la double authentification et la formation (des mots de passe uniques pour chaque service) pour 650 €. Le remplacement des **postes obsolètes** (M4) doit aussi être programmé : un poste sans mises à jour reste une porte d'entrée, même s'il « rapporte » moins de points.

Corrigé – Exercice 21.48

Partie A – Analyser le projet

1.

Donnée	Donnée de santé ?	Utile au but éducatif ?
Identité, photo d'identité	Non	Identité utile ; photo inutile
Numéro de sécurité sociale	Non (mais très sensible)	**Inutile**
Ordonnance de cure avec diagnostic	**Oui**	**Inutile** à l'application (les thermes l'ont déjà)
Photos des repas et calories estimées	Peut le devenir (habitudes alimentaires liées à une pathologie)	Utile seulement si analysées avec la diététicienne
Poids quotidiens	**Oui**	Peu utile chaque jour ; une pesée hebdomadaire suffit
Classement	**Oui** (perte de poids d'une personne reconnaissable)	**Inutile**, et nocif

2. **Élément 1** : numéro de sécurité sociale et ordonnance stockés par une entreprise : risque d'usurpation et de divulgation de données de santé ; **mesure** : ne pas les collecter (minimisation). **Élément 2** : estimation des calories par une IA, souvent imprécise : risque de culpabilisation ou de mauvais choix alimentaires ; **mesure** : utiliser la photo comme support de discussion en atelier, sans chiffre affiché comme vérité. **Élément 3** : poids envoyé automatiquement, chaque jour : risque de fuite et d'obsession de la balance ; **mesure** : pesée hebdomadaire avec la diététicienne, ou balance non connectée. **Élément 5** : hébergement chez un fournisseur non certifié HDS et Wi-Fi unique : non-conformité à l'article L1111-8 et risque d'attaque des postes administratifs depuis les tablettes ; **mesure** : hébergeur certifié HDS, contrat de sous-traitance (article 28), réseaux séparés.

3. **Confidentialité** : afficher la perte de poids de personnes reconnaissables dévoile une donnée de santé à tous les curistes, visiteurs et salariés ; aucun consentement ne la rend acceptable dans un lieu public. **Éthique** : stigmatisation des personnes qui perdent peu, compétition, pression sur des personnes vulnérables. **Éducation nutritionnelle** : la HAS insiste sur la qualité de vie et la prévention de la reprise, pas sur une perte rapide ; un classement encourage des comportements dangereux (restriction sévère, déshydratation avant la pesée).

4. **Trois réseaux séparés** : bureaux et soins (professionnels seulement), tablettes prêtées (isolé, accès uniquement à la plateforme), Wi-Fi des curistes (invité, isolé). Tablettes : comptes réinitialisés **entre deux**

curistes (effacement des données et déconnexion), verrouillage par code, mises à jour gérées, aucune application installée par le curiste.

Partie B – L'incident et les chiffres

5. Taux de clic : 138 / 552 = **25,0 %** ; taux de saisie : 41 / 552 = **7,4 %** ; part des curistes ayant cliqué qui ont saisi leurs identifiants : 41 / 138 = **29,7 %**. Conditions : n = 552 ≥ 30, n × p = 138 ≥ 5, n × (1 – p) = 414 ≥ 5. Marge : 1,96 × √(0,25 × 0,75 / 552) ≈ 0,036 ; IC à 95 % ≈ **[21,4 % ; 28,6 %]**. Un curiste sur quatre a cliqué : le message était **crédible**, car il imitait un service réel, juste après la cure, et utilisait sans doute les adresses volées. Près de 3 curistes sur 10 qui cliquent donnent leurs identifiants : il faut les prévenir et leur faire changer leur mot de passe.

6. Les **thermes** sont responsables du traitement (ils décident du programme et de ses finalités) ; l'**entreprise** est sous-traitant (article 28). Ce sont les thermes qui **notifient la CNIL**, dans les 72 heures après en avoir eu connaissance : mercredi 17 mai, 15 h + 72 h = **samedi 20 mai, 15 h**. Les curistes **doivent être informés** (article 34) : numéros de sécurité sociale, ordonnances et poids accessibles à tous pendant trois jours : **risque élevé** (usurpation, hameçonnage ciblé, atteinte à la vie privée). Le délai de l'entreprise (du lundi 9 h au mercredi 15 h, soit **54 heures**) est **trop long** : un sous-traitant doit informer « dans les meilleurs délais » ; le contrat doit fixer un délai court (par exemple 24 heures).

7. Curistes sur 3 ans : 4 800 × 3 = 14 400. **A** : 18 × 14 400 = **259 200 €**, soit **18 €** par curiste. **B** : 42 000 + 4 × 14 400 = **99 600 €**, soit 99 600 / 14 400 ≈ **6,92 €** par curiste. B coûte **159 600 €** de moins sur 3 ans.

8. Le faux courriel arrive **le lendemain** de l'alerte aux thermes et vise exactement les 552 adresses du pilote, en imitant ThermoForme : les attaquants ont très probablement **récupéré les adresses** dans la base exposée pour mener un hameçonnage ciblé.

Partie C – Décider et communiquer

9. **Recommandation : option B**, moins chère, conforme (hébergeur certifié HDS) et centrée sur l'éducation. **Mesures prioritaires** : (1) notification à la CNIL et information des 600 curistes ; (2) fin du pilote ThermoForme, récupération puis **suppression** des données par l'entreprise, avec attestation ; (3) **séparation des réseaux** Wi-Fi et réinitialisation des tablettes entre curistes ; (4) contrat de sous-traitance pour la nouvelle plateforme (sécurité, délai d'information de 24 heures, réversibilité) et **analyse d'impact** avec le DPO avant le lancement ; pas de classement ni de balance connectée. **Indicateurs** : part des curistes qui suivent au moins 3 ateliers ; nombre d'incidents de sécurité déclarés par trimestre ; satisfaction des curistes sur les ateliers ; délai moyen de réinitialisation des tablettes (cible : avant l'arrivée du curiste suivant).

10. Exemple : « Madame, Monsieur, vous avez participé au printemps 2028 au programme ThermoForme. Le prestataire de l'application nous a informés qu'entre le 12 et le 15 mai, sa base de données a été accessible sur Internet : votre identité, votre numéro de sécurité sociale, votre ordonnance de cure et vos poids ont pu être consultés. Le 18 mai, un faux courriel "ThermoForme – téléchargez votre bilan" a été envoyé : **ne cliquez pas** et supprimez-le. Si vous avez saisi votre mot de passe, changez-le, ainsi que sur tous les sites où vous l'utilisez. Méfiez-vous des appels ou messages qui citent votre cure. Nous avons notifié la CNIL et arrêté le programme. Pour toute question : [numéro] ou le délégué à la protection des données [adresse]. »

11. Exemple : **objectif** : chaque curiste repère trois signes d'un message piégé et sait quelles données de santé ne pas partager. **Déroulement** : 5 min : « Quelles applications de santé utilisez-vous ? » ; 10 min : jeu sur des exemples (faux courriel ThermoForme anonymisé, fausse publicité pour une cure minceur, vraie application recommandée) ; 5 min : les bons réflexes (je ne donne pas mon numéro de sécurité sociale à une application, je vérifie qui héberge mes données, je signale sur 17Cyber). **Support** : fiche en gros caractères à emporter.

12. Exemple : « L'erreur technique vient de l'entreprise, mais les thermes sont **responsables du traitement** : c'est vous qui avez choisi ce prestataire et décidé de collecter ces données. Le RGPD vous oblige à vérifier les garanties du sous-traitant, à notifier la CNIL et à informer les curistes. Pour eux, c'est le nom des thermes qui compte. Reconnaître notre part et réagir vite, c'est protéger leur confiance. »

Bilan : grille d'auto-évaluation

Partie	Je sais…	Exercices	Acquis	En cours	À retravailler
1	Citer les acteurs ; classer un incident selon la disponibilité, l'intégrité et la confidentialité ; employer les mots menace, vulnérabilité, risque ; exploiter un bilan d'incidents ; mesurer les effets d'une panne ; situer les textes	21.1 à 21.6			
2	Appliquer les gestes d'hygiène ; juger des sauvegardes (règle 3-2-1) ; calculer des données perdues ; prioriser des mises à jour ; appliquer le moindre privilège ; choisir un outil de stockage	21.7 à 21.12			
3	Juger un mot de passe ; calculer un temps de recherche ; expliquer la double authentification ; chiffrer un gestionnaire de mots de passe ; supprimer un compte partagé ; réagir à une fuite	21.13 à 21.18			
4	Reconnaître une action malveillante ; repérer un message piégé ; répondre à un appel suspect ; empêcher une fraude au virement ; analyser un rançongiciel ; protéger des patients des arnaques	21.19 à 21.24			
5	Ordonner la réaction à un incident ; calculer le délai de 72 heures ; rédiger une fiche réflexe ; organiser un mode dégradé ; chiffrer une journée en mode dégradé ; conduire un retour d'expérience	21.25 à 21.30			
6	Construire une sensibilisation ; calculer des taux de clic et de signalement ; calculer un intervalle de confiance ; exploiter un questionnaire avant et après ; animer un quart d'heure ; suivre un tableau de bord	21.31 à 21.36			
7	Travailler hors de la structure ; analyser un objet connecté ; coter des risques ; chiffrer la sécurité d'une petite structure ; séparer les réseaux Wi-Fi ; effacer du matériel avant un don	21.37 à 21.42			
8	Construire une check-list de projet ; corriger une charte ; répondre au jury ; rédiger une note de décision ; choisir des mesures sous contrainte de budget ; traiter un cas complet sur 40 points	21.43 à 21.48			

Conseil : refaites une semaine plus tard les exercices notés « à retravailler », sans regarder le corrigé, puis comparez.